EV Monitor

ระบบบริหารจัดการกองยานรถยนต์ไฟฟ้า

เอกสารออกแบบระบบ

System Design Document

รายการ	รายละเอียด
เวอร์ชันเอกสาร	1.0
วันที่	15 ตุลาคม 2026
อ้างอิงโค้ด	repository PrjLOMO สาขา main (commit d73864f)
ระบบใช้งานจริง	https://monitor.lomo2u.com
เนื้อหา	สถาปัตยกรรม · แผนภาพการไหลของข้อมูล (DFD) · ฐานข้อมูล (ER) · API · ความปลอดภัย · การติดตั้ง

สารบัญ

1. บทนำ 4
1.1 วัตถุประสงค์ของเอกสาร 4
1.2 ขอบเขตของระบบ 4
1.3 ผู้อ่านและวิธีใช้เอกสาร 4
1.4 คำศัพท์และตัวย่อ 4
1.5 เอกสารอ้างอิง 5
2. ภาพรวมระบบและความต้องการ 6
2.1 ภาพรวม 6
2.2 ผู้ใช้และบทบาท 6
2.3 ฟังก์ชันหลัก 6
2.4 ความต้องการนอกเหนือฟังก์ชัน 7
2.5 ข้อจำกัดและสมมติฐาน 7
3. สถาปัตยกรรมระบบ 8
3.1 หลักการออกแบบ 8
3.2 แผนภาพสถาปัตยกรรมระบบ (System Architecture) 9
3.3 ส่วนประกอบของระบบ 10
3.4 เทคโนโลยีที่ใช้ 10
3.5 การตัดสินใจสถาปัตยกรรมที่สำคัญ 11
4. การออกแบบส่วนประกอบ 12
4.1 เว็บแอป (Next.js) 12
4.2 API (Fastify) 12
4.3 งานเบื้องหลัง 13
4.4 การแจ้งเตือนหลายช่องทาง 13
4.5 การสำรองและกู้คืน 14
5. การไหลของข้อมูล (Data Flow) 15
5.1 DFD ระดับ 0: กระแสข้อมูลเข้า-ออกระบบ 17
5.2 DFD ระดับ 1: กระบวนการภายในระบบ 19
5.3 ลำดับขั้นของเหตุการณ์สำคัญ 20
6. การออกแบบฐานข้อมูล 22
6.1 แผนภาพ ER (Entity-Relationship) 23
6.2 กลุ่มตาราง 24
6.3 ชนิดค่า (enum) 24
6.4 ข้อกำหนดและกลไกในฐานข้อมูล 24
6.5 การจัดการ schema และ migration 25
7. การออกแบบ API 26
7.1 ข้อตกลงทั่วไป 26

7.2 กลุ่มเส้นทาง 26
7.3 Ingest API (อุปกรณ์/ระบบภายนอก) 27
7.4 เรียลไทม์ (SSE) 27
8. ความปลอดภัย 28
8.1 การยืนยันตัวตนและเซสชัน 28
8.2 การยืนยันตัวตนสองขั้น (2FA) 28
8.3 การควบคุมสิทธิ์ 28
8.4 ความปลอดภัยของเว็บและการสื่อสาร 29
8.5 บันทึกกิจกรรมและการแจ้งเตือนความผิดปกติ 29
8.6 ความลับและการเข้ารหัสข้อมูล 29
8.7 ภัยคุกคามและมาตรการ 29
8.8 สิ่งที่ผู้ดูแลต้องทำเอง 30
9. การติดตั้งและการปฏิบัติการ 31
9.1 สภาพแวดล้อม 31
9.2 โครงสร้างการติดตั้ง production 31
9.3 ตัวแปรสภาพแวดล้อม (`.env`) 31
9.4 ขั้นตอนอัปเดตระบบ 32
9.5 สำรองและกู้คืน 33
9.6 การเฝ้าระวัง 33
9.7 ข้อควรรู้เรื่องอีเมลบนคลาวด์ 33
10. การทดสอบและประกันคุณภาพ 34
11. ข้อจำกัด ความเสี่ยง และแนวทางต่อไป 35
11.1 ข้อจำกัดและความเสี่ยงที่ทราบ 35
11.2 แนวทางพัฒนาต่อ (เรียงตามความสำคัญ) 35
ภาคผนวก ก. รายการตารางในฐานข้อมูล (27 ตาราง) 36
ภาคผนวก ข. คำสั่งที่ใช้บ่อย 37

1. บทนำ

1.1 วัตถุประสงค์ของเอกสาร

เอกสารนี้อธิบายการออกแบบระบบ **EV Monitor** (ระบบบริหารจัดการกองยานรถยนต์ไฟฟ้า) ครอบคลุมสถาปัตยกรรม การไหลของข้อมูล การออกแบบฐานข้อมูลและ API ความปลอดภัย และการติดตั้ง/ปฏิบัติการ เพื่อใช้เป็นฐานร่วมกันสำหรับการพัฒนาต่อ การตรวจสอบ และการส่งมอบระบบ

เนื้อหาทั้งหมดอ้างอิงจากโค้ดและการตั้งค่าที่ใช้งานจริง ณ เวอร์ชันที่ระบุในหน้าปก ไม่ใช่แผนที่ยังไม่ได้ทำ ส่วนที่ยังไม่มีหรือเป็นข้อจำกัดถูกแยกไว้ในบทที่ 11 อย่างชัดเจน

1.2 ขอบเขตของระบบ

- **อยู่ในขอบเขต:** เว็บแอปสำหรับผู้ดูแล/ผู้จัดการ/ผู้ดูรายงาน, REST API, รับข้อมูลจากอุปกรณ์ (ingest), ฐานข้อมูล PostgreSQL, งานเบื้องหลัง (ตรวจรถออฟไลน์ แจ้งเตือน สรุปรายวัน รายงานตามตารางเวลา), การยืนยันตัวตนสองชั้น, บันทึกกิจกรรม, สำรองข้อมูลและส่งออกนอกเครื่องแบบเข้ารหัส, การติดตั้งด้วย Docker Compose พร้อม HTTPS
- **อยู่นอกขอบเขต/ยังไม่ทำ:** การส่ง SMS, การสร้างไฟล์ PDF จากเซิร์ฟเวอร์ (ปัจจุบัน PDF คือการพิมพ์หน้ารายงานด้วย print CSS), SSO ขององค์กร (ปุ่มยังไม่เชื่อมต่อ), การรันหลายอินสแตนซ์ของ API (ดูข้อจำกัดในบทที่ 11), การเชื่อมต่อโดยตรงกับผู้ผลิตรถ (ข้อมูลรถต้องส่งเข้ามาผ่าน API ingest)

1.3 ผู้อ่านและวิธีใช้เอกสาร

ผู้อ่าน	อ่านบทที่	เพื่อ
ทีมพัฒนา	3–7, ภาคผนวก	เข้าใจโครงสร้างโค้ด ข้อตกลง และจุดที่ต้องแก้คู่กัน
ผู้ดูแลระบบ/DevOps	3, 8, 9	ติดตั้ง อัปเดต สำรอง/กู้คืน และเฝ้าระวัง
ผู้ตรวจสอบความปลอดภัย	5, 8, 11	ตรวจกลไกป้องกัน ข้อมูลที่เก็บ และความเสี่ยงที่เหลือ
ผู้ตัดสินใจ/เจ้าของระบบ	1–3, 11	เห็นภาพรวม ขอบเขต ข้อจำกัด และงานถัดไป

1.4 คำศัพท์และตัวย่อ

คำ	ความหมาย
SOC / SOH	ระดับประจุแบตเตอรี่ (State of Charge, %) / สุขภาพแบตเตอรี่ (State of Health, %)
Telemetry	ข้อมูลที่อุปกรณ์ในรถส่งเป็นระยะ เช่น SOC ความเร็ว ตำแหน่ง อุณหภูมิแบต
Ingest	ชุดเส้นทาง API (`/api/v1/ingest/*`) ที่อุปกรณ์หรือระบบภายนอกใช้ส่งข้อมูลเข้า ยืนยันตัวด้วย API key
TCO	ต้นทุนรวมตลอดอายุการใช้งาน (Total Cost of Ownership) ใช้เทียบรถสันดาปกับรถ EV
JWT	โทเคนที่เซิร์ฟเวอร์ลงลายเซ็น (HS256) เก็บใน cookie ชื่อ `ev_session` เป็นหลักฐานการล็อกอิน
RBAC	การควบคุมสิทธิ์ตามบทบาท (admin > manager > viewer)
TOTP / 2FA	รหัสผ่านใช้ครั้งเดียวตามเวลา 6 หลัก (RFC 6238) จากแอป Authenticator ใช้เป็นการยืนยันขั้นที่สอง
SSE	Server-Sent Events: ช่องทางที่เซิร์ฟเวอร์ส่งสัญญาณ "ข้อมูลเปลี่ยน" ไปหาเบราว์เซอร์
CSP	Content-Security-Policy: นโยบายที่เบราว์เซอร์ใช้จำกัดว่าหน้าเว็บโหลดสคริปต์/รูปจากที่ใดได้
DFD / ER	แผนภาพการไหลของข้อมูล (Data Flow Diagram) / แผนภาพความสัมพันธ์ระหว่างตาราง (Entity-Relationship)

คำ	ความหมาย
age	เครื่องมือเข้ารหัสไฟล์ด้วยกุญแจสาธารณะ ใช้เข้ารหัสไฟล์สำรอง ผู้ถือกุญแจส่วนตัวเท่านั้นถอดรหัสได้
SPF / DKIM / DMARC	ระเบียน DNS ที่ยืนยันว่าอีเมลที่อ้างโดเมนส่งมาจากผู้ที่ได้รับอนุญาตจริง
ACME	โปรโตคอลขอใบรับรอง HTTPS อัตโนมัติ (Let's Encrypt)

1.5 เอกสารอ้างอิง

ไฟล์ในโปรเจกต์	เนื้อหา
`CLAUDE.md`	สถานะโครงการ ข้อตกลงการพัฒนา และสิ่งที่ต้องระวังในแต่ละส่วน
`SECURITY.md`	ผลทบทวนความปลอดภัย สิ่งที่แก้แล้ว และรายการที่ต้องทำก่อนใช้งานจริง
`db/README.md`	โครงสร้างฐานข้อมูล migration การสำรอง/กู้คืน และ offsite backup
`api/README.md`	รายการเส้นทาง API และวิธีทดสอบ
`design/HANDOFF.md` และ `design/prototype/`	สเปกการส่งต่องานและต้นแบบหน้าจอที่เป็นแหล่งอ้างอิงด้านหน้าตา

2. ภาพรวมระบบและความต้องการ

2.1 ภาพรวม

EV Monitor ช่วยให้องค์กรที่ใช้รถยนต์ไฟฟ้าหลายคันเห็นสถานะกองยานแบบเรียลไทม์ ได้แก่ ตำแหน่ง ระดับแบตเตอรี่ การชาร์จ พฤติกรรมการขับขี่ และแจ้งเตือนเมื่อมีเหตุผิดปกติ พร้อมรายงานพลังงาน คาร์บอน และต้นทุน รวมถึงประเมินความพร้อมในการเปลี่ยนรถสันดาปเป็น EV หน้าจอทั้งหมดเป็นภาษาไทยและใช้งานบนมือถือได้

2.2 ผู้ใช้และบทบาท

บทบาท	ชื่อในระบบ	สิทธิ์โดยสรุป
admin	ผู้ดูแลระบบ	ทุกอย่าง: จัดการผู้ใช้/เชิญ/ปิดบัญชี/รีเซ็ต 2FA, ตั้งค่าระบบ, API key, บันทึกกิจกรรม, นโยบายความปลอดภัย
manager	ผู้จัดการกองยาน	ดูและแก้ข้อมูลกองยาน (รถ คนขับ สถานีชาร์จ การชาร์จ ซ่อมบำรุง) รายงาน และตั้งเวลาส่งรายงาน
viewer	ผู้ดูรายงาน	ดูรายงานและข้อมูลสรุปแบบอ่านอย่างเดียว
(อุปกรณ์/ระบบภายนอก)	ผู้เรียก ingest	ไม่ใช่ผู้ใช้: ใช้ API key (เก็บเป็น hash) ส่งข้อมูลเข้า `/api/v1/ingest/*` เท่านั้น

ลำดับสิทธิ์คือ admin > manager > viewer บทบาทและสถานะของผู้ใช้ถูกอ่านจากฐานข้อมูลทุกคำขอ (ไม่เชื่อค่าในโทเคน) การเปลี่ยนบทบาทหรือปิดบัญชีจึงมีผลทันที

2.3 ฟังก์ชันหลัก

โมดูล	ความสามารถ	หน้า / เส้นทางหลัก
แดชบอร์ด	สรุปจำนวนรถตามสถานะ แบตต่ำ การชาร์จ แจ้งเตือน และแผนที่ย่อ	/dashboard
แผนที่	ตำแหน่งรถและสถานีชาร์จ (ภาพแผนที่จาก OpenStreetMap)	/map
รถ	รายการ (ค้นหา กรอง เรียง แบ่งหน้า), รายละเอียด, เพิ่ม/แก้ไข, ซ่อมบำรุง	/vehicles, /vehicles/[id]
แบตเตอรี่	ภาพรวมสุขภาพแบต SOH ระดับประจุ และข้อมูลเชิงลึก	/battery
การชาร์จ	เซสชันที่กำลังชาร์จ ประวัติ โหลดไฟรวม สถานี (เพิ่ม/แก้/ลบ) เป้าหมายชาร์จ	/charging
คนขับ	คะแนนการขับขี่ เหตุการณ์ (เบรกกะทันหัน ฯลฯ) อันดับ รถประจำ	/drivers
แจ้งเตือน	ระดับวิกฤต/เตือน/ข้อมูล รับทราบทีละรายการหรือทั้งหมด กฎและช่องทางแจ้งเตือน	/alerts
รายงาน	พลังงาน ต้นทุน คาร์บอน ESG, ความพร้อมเปลี่ยนเป็น EV และ TCO, ส่งออก Excel/พิมพ์ PDF, ตั้งเวลาส่งอีเมล, สมมติฐานของรายงาน	/reports
ตั้งค่า	องค์กร เกณฑ์แจ้งเตือน ค่าไฟ ผู้ใช้และสิทธิ์ การเชื่อมต่อ API key นโยบายบังคับ 2FA บันทึกกิจกรรม	/settings
บัญชีของฉัน	เปลี่ยนรหัสผ่าน, เปิด/ปิด 2FA และรหัสสำรอง, เลือกรับอีเมลแจ้งเตือนรายบุคคล	/account
การเข้าถึง	เข้าสู่ระบบ ลืมรหัสผ่าน ตอบรับคำเชิญ (ลิงก์ใช้ครั้งเดียว)	/login, /forgot-password, /reset-password/[token], /invite/[token]
หน้าแรกสาธารณะ	หน้าแนะนำระบบ พร้อมตัวเลขภาพรวมที่ไม่ระบุตัวตน	/, GET /api/v1/public/overview

2.4 ความต้องการนอกเหนือฟังก์ชัน

ด้าน	ความต้องการและวิธีที่ระบบตอบสนอง
ความปลอดภัย	รหัสผ่านแฮชด้วย bcrypt, 2FA, จำกัดการเดารหัสทั้งรายบัญชีและรายไอพี, CSP แบบ nonce, บันทึกกิจกรรมแก้ไขไม่ได้, เตือนผู้ใช้เมื่อมีความผิดปกติ (รายละเอียดบทที่ 8)
ความพร้อมใช้งาน	ทุกบริการ restart อัตโนมัติ (`unless-stopped`) มี healthcheck; งานเบื้องหลังแยกกัน งานหนึ่งพังไม่หยุดงานอื่น; ระบบเดี่ยว (ไม่มี HA)
ประสิทธิภาพ	แบ่งหน้าฝั่งเซิร์ฟเวอร์ (≤100 ต่อหน้า) พร้อมสรุปทั้งกอง; ดัชนีบนคอลัมน์ที่ค้นหาบ่อย; ใช้งานจริงบนเครื่อง 1 vCPU/RAM ~0.5 GB (ใช้หน่วยความจำรวม ~280 MB)
การใช้งานบนมือถือ	เมนูข้างเป็น off-canvas เมื่อกว้าง ≤ 900px; ทดสอบหน้าหลักบนมุมมองมือถือแล้ว
ภาษาและเวลา	ข้อความทั้งหมดเป็นภาษาไทย ฟอนต์ IBM Plex Sans Thai (self-host); เวลาแสดงผลและกำหนดงานเป็นเวลาไทย (Asia/Bangkok) ชื่อไฟล์ใช้วันที่ไทย ไม่ใช่ UTC
การตรวจสอบย้อนหลัง	เก็บบันทึกกิจกรรม 365 วัน (ตั้งได้ ขั้นต่ำ 30) ทุกการแก้ข้อมูลที่สำเร็จถูกบันทึกอัตโนมัติ
การกู้คืน	สำรองรายวัน (RPO ≈ 24 ชม.) ตรวจไฟล์ก่อนนับว่าสำเร็จ ส่งออกนอกเครื่องแบบเข้ารหัส และมีสคริปต์ทดสอบกู้
การบำรุงรักษา	schema เปลี่ยนผ่าน migration ที่รันซ้ำได้; API ตรวจและแจ้งเมื่อ migration ขาดตอนเริ่มระบบ; ชุดทดสอบ API 232 รายการ

2.5 ข้อจำกัดและสมมติฐาน

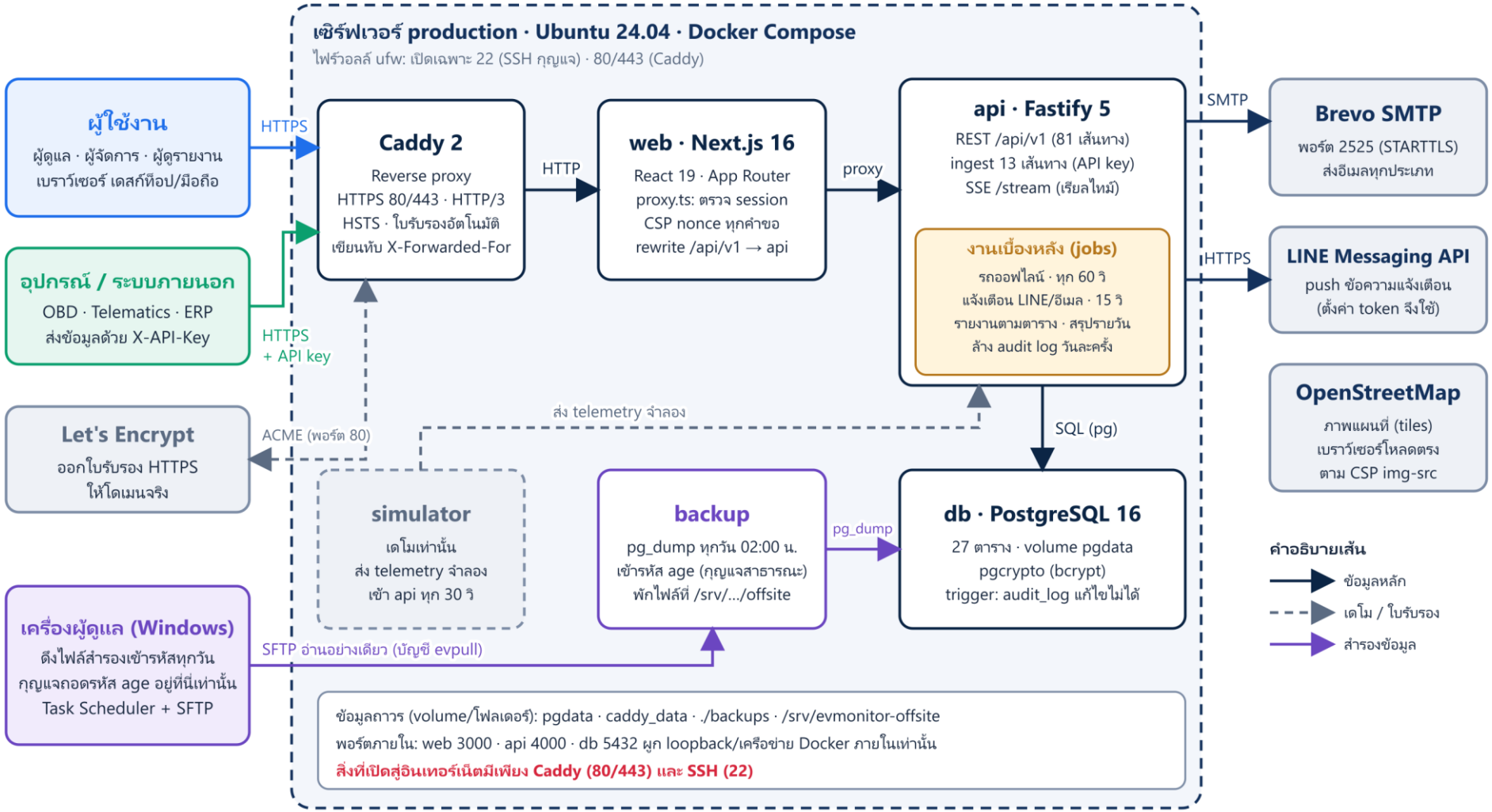
- API ทำงานเป็นอินสแตนซ์เดียว: บัสเหตุการณ์ SSE และตัวนับการล็อกอินผิดอยู่ในหน่วยความจำ
- ฐานข้อมูลเป็น PostgreSQL ตัวเดียว ไม่มีการทำสำเนา (replica)
- ข้อมูลรถมาจากอุปกรณ์/ระบบภายนอกผ่าน ingest เท่านั้น ระบบไม่ดึงจากผู้ผลิตรถเอง
- ผู้ให้บริการคลาวด์ที่ใช้งานจริง (DigitalOcean) บล็อกพอร์ตส่งอีเมลขาออก 25/465/587 จึงใช้ SMTP พอร์ต 2525 ผ่าน Brevo
- ผู้ใช้ใช้เบราว์เซอร์สมัยใหม่ที่รองรับ SSE, CSP และ ES2020

3. สถาปัตยกรรมระบบ

3.1 หลักการออกแบบ

- **แยกหน้าที่เป็น container:** `web` (หน้าเว็บ) · `api` (ตรรกะและข้อมูล) · `db` (จัดเก็บ) แต่ละส่วนรันและเปลี่ยนได้อิสระ
- **เว็บเป็นด่านเดียวของเบราว์เซอร์:** เบราว์เซอร์เรียก `/api/v1/*` ที่โดเมนเดียวกับเว็บ แล้วเว็บส่งต่อไป API จึงใช้ cookie httpOnly ได้โดยไม่ต้องตั้ง CORS
- **API เป็นแหล่งความจริงเดียว:** สิทธิ์ การตรวจข้อมูล และบันทึกกิจกรรมอยู่ที่ API เว็บไม่ตัดสินสิทธิ์เอง (ตรวจฝั่งเว็บเพื่อประสบการณ์ใช้งานเท่านั้น)
- **ปลอดภัยโดยปริยาย (secure by default):** ฟีเจอร์ที่ส่งข้อมูลออกนอก (อีเมล LINE offsite backup) ปิดอยู่จนกว่าจะตั้งค่า ข้อมูลลับอยู่ใน `.env` ที่ไม่เข้า git
- **ล้มเหลวอย่างปลอดภัย:** งานเบื้องหลังแยกกัน ส่งอีเมลไม่ได้ไม่ทำให้คำขอล้ม เหตุการณ์ยังบันทึกในฐานข้อมูลเสมอ
- **เปลี่ยนแปลงได้ตรวจสอบได้:** ทุก schema ผ่าน migration ทุกการแก้ข้อมูลมีร่องรอย ทุกจุดสำคัญมีเทสต์

3.2 แผนภาพสถาปัตยกรรมระบบ (System Architecture)



รูปที่ 1 สถาปัตยกรรมระบบ EV Monitor: container ภายในเครื่อง ระบบภายนอก และเส้นทางข้อมูล

3.3 ส่วนประกอบของระบบ

รูปที่ 1 แสดงส่วนประกอบทั้งหมดที่รันบนเซิร์ฟเวอร์เดียวด้วย Docker Compose และระบบภายนอกที่เชื่อมต่อ ตารางต่อไปนี้อธิบายหน้าที่ของแต่ละส่วน

ส่วนประกอบ	เทคโนโลยี	หน้าที่	พอร์ต / การเข้าถึง
caddy	Caddy 2	Reverse proxy ด่านหน้า: HTTPS อัตโนมัติ (Let's Encrypt), เปลี่ยน HTTP เป็น HTTPS, ส่ง HSTS, เขียนทับ `X-Forwarded-For` ด้วย IP ผู้เรียกจริง	80, 443 (TCP) และ 443 (UDP/HTTP3) เปิดสู่อินเทอร์เน็ต
web	Next.js 16, React 19	หน้าเว็บทั้งหมด; `proxy.ts` ตรวจ session ตั้ง CSP nonce และกรอง header; ส่งต่อ `/api/v1/*` ไป api	3000 ผูก loopback (ผ่าน caddy เท่านั้น)
api	Fastify 5, TypeScript	REST API 81 เส้นทาง + ingest 13 เส้นทาง (รวม 94), SSE, งานเบื้องหลัง, OpenAPI ที่ `/docs`	4000 ผูก loopback/เครือข่ายภายใน
db	PostgreSQL 16	ฐานข้อมูลหลัก 27 ตาราง; pgcrypto สำหรับ bcrypt; trigger ปกป้อง audit_log	5432 ผูก loopback; ข้อมูลใน volume `pgdata`
backup	pg_dump + age + rclone	สำรองรายวัน ตรวจไฟล์ เข้ารหัสด้วยกุญแจสาธารณะ พักที่โฟลเดอร์ให้เครื่องผู้ดูแลดึง	ไม่เปิดพอร์ต
simulator	Node (image เดียวกับ api)	เดโมเท่านั้น: ส่ง telemetry จำลองเข้า api เพื่อให้รถเดโมไม่ออฟไลน์	ไม่เปิดพอร์ต; ไม่ใช้เมื่อมีอุปกรณ์จริง
mailpit	Mailpit	พัฒนา/เดโมเท่านั้น: กล่องจดหมายทดสอบ (ไม่ใช้บน production)	8025 ผูก loopback
Brevo SMTP	ภายนอก	ส่งอีเมลทุกประเภทผ่านพอร์ต 2525 (STARTTLS) ต้องขึ้นรายการ IP ที่อนุญาต	ขาออก
LINE Messaging API	ภายนอก	ส่งข้อความแจ้งเตือนวิกฤต/เตือน (ใช้เมื่อตั้ง token)	ขาออก HTTPS
OpenStreetMap	ภายนอก	ภาพแผนที่; เบราว์เซอร์โหลดตรง (CSP อนุญาตเฉพาะโดเมนนี้)	เบราว์เซอร์ → OSM

3.4 เทคโนโลยีที่ใช้

ชั้น	เทคโนโลยี	หมายเหตุ
หน้าเว็บ	Next.js 16 (App Router), React 19, TypeScript	ไม่ใช้ Tailwind; สไตล์จาก design tokens (`tokens.css`) ตามต้นแบบ
กราฟ/แผนที่	Chart.js + react-chartjs-2, Leaflet + react-leaflet	ภาพแผนที่จาก OpenStreetMap
ฟอนต์/ไอคอน	IBM Plex Sans Thai (self-host ผ่าน next/font), ไอคอนเส้นชุดเดียวกับต้นแบบ	ไม่เรียก Google ตอนใช้งาน
API	Fastify 5, TypeBox (ตรวจข้อมูลและสร้าง OpenAPI), pg, nodemailer, exceljs	ไม่ใช้ ORM — SQL ตรงแบบ parameterized
ฐานข้อมูล	PostgreSQL 16 + pgcrypto	เวลา timezone Asia/Bangkok
การเข้ารหัส	`node:crypto`: JWT HS256, AES-256-GCM (HKDF), TOTP RFC 6238, sha256	เขียนเองแบบบางเพื่อไม่เพิ่ม dependency; มีเทสต์เวกเตอร์ของ RFC
การสำรอง	pg_dump (custom), age, rclone, OpenSSH SFTP	ภาพ container `backup` มีเครื่องมือครบ
การรัน	Docker Compose, Caddy 2	โปรไฟล์ `https` (Caddy) และ `demo` (simulator, mailpit)

ชั้น	เทคโนโลยี	หมายเหตุ
การทดสอบ	node:test + tsx	ทดสอบกับ PostgreSQL จริง แยกฐานข้อมูลต่อชุด

3.5 การตัดสินใจสถาปัตยกรรมที่สำคัญ

เรื่อง	ตัดสินใจ	เหตุผลและผลที่ตามมา
ทางเข้าเบราว์เซอร์	เว็บส่งต่อ `/api/v1/*` ไป API (rewrite)	โดเมนเดียว → cookie httpOnly/SameSite ใช้ได้ ไม่ต้องเปิด CORS; แลกกับการที่เว็บต้องทำงานอยู่เสมอ
เซสชัน	JWT ใน cookie แต่ตรวจกับฐานข้อมูลทุกคำขอ (`session_version`)	เพิกถอนทันทีเมื่อเปลี่ยนรหัส/ปิดบัญชี/เปิด-ปิด 2FA; แลกกับ 1 query ต่อคำขอ
เรียลไทม์	SSE ส่งเฉพาะสัญญาณ "change" ไม่มีเนื้อข้อมูล	ไม่มีข้อมูลรั่วทางสตรีม เว็บโหลดซ้ำผ่าน API ที่ตรวจสิทธิ์ตามปกติ; บัสอยู่ในหน่วยความจำ จึงใช้ได้กับ API อินสแตนซ์เดียว
CSP	nonce ต่อคำขอ + `force-dynamic` ทุกหน้า	สคริปต์ที่แทรกเข้ามารันไม่ได้; แลกกับการไม่มีหน้า static (ห้ามถอด `force-dynamic`)
2FA / การเข้ารหัสข้อมูลลับ	เขียน TOTP และ AES-GCM เอง ผูกกุญแจกับ `AUTH_SECRET` (HKDF แยกตามวัตถุประสงค์)	ฐานข้อมูลหลุดอย่างเดียวยังอ่านความลับ 2FA ไม่ได้; แลกกับการที่เปลี่ยน `AUTH_SECRET` แล้วต้องรีเซ็ต 2FA ทุกคน
บันทึกกิจกรรม	hook `onSend` บันทึกทุกคำขอแก้ข้อมูลที่สำเร็จ	เส้นทางใหม่ถูกบันทึกอัตโนมัติ ไม่มีรายการหลุด; เขียนก่อนตอบ ไม่เก็บค่าที่ผู้ใช้กรอก
สำรองนอกเครื่อง	เซิร์ฟเวอร์เข้ารหัสด้วยกุญแจสาธารณะ เครื่องผู้ดูแลดึงผ่าน SFTP อ่านอย่างเดียว	ไม่ต้องมี bucket; เซิร์ฟเวอร์ไม่มีกุญแจถอดรหัส; แลกกับการต้องมีเครื่องผู้ดูแลเปิดอยู่
การส่งมอบ image	build บนเครื่องพัฒนา แล้ว `docker save | ssh | docker load`	เซิร์ฟเวอร์ RAM ~0.5 GB build Next.js ไม่ได้; ไม่ต้องมี registry

4. การออกแบบส่วนประกอบ

4.1 เว็บแอป (Next.js)

- **โครงเส้นทาง:** `app/src/app/(app)/*` คือหน้าที่ต้องล็อกอิน (dashboard, map, vehicles, battery, charging, drivers, alerts, reports, settings, account) ส่วน `/login`, `/forgot-password`, `/reset-password/[token]`, `/invite/[token]` และหน้าแรก `/` เป็นหน้าสาธารณะ
- **`proxy.ts` (ตัวกรองคำขอ) ทำ 3 อย่าง:** ตรวจ cookie session ด้วย `AUTH_SECRET` แล้วพาไป `/login` ถ้าไม่ผ่าน · สร้าง CSP พร้อม nonce ของคำขอ · เก็บกวาด `X-Forwarded-For` ก่อนส่งต่อ API (ใช้ค่าท้ายสุดที่ proxy ของเราเติมเท่านั้น)
- **ชั้นข้อมูล:** `app/src/api/` เรียก API จริง (`http.ts` แปลงข้อผิดพลาด 401 → ไปหน้าล็อกอิน) แล้วแปลง DTO เป็นรูปที่หน้าเว็บใช้ (`mappers.ts`); ฟอร์มรับข้อผิดพลาดรายฟิลด์จาก API (400/403/404/409/410/422) แสดงใต้ช่อง
- **เรียลไทม์:** `LiveProvider` เปิด SSE; หน้าที่ใช้ `useAsync(fn, deps, { live: true })` โหลดซ้ำเงียบ ๆ เมื่อได้รับสัญญาณ
- **หน้าตา:** ค่าสี/ขนาดฟอนต์ทั้งหมดอยู่ใน `tokens.css` (ห้ามใส่ค่า hex ดิบที่อื่น) คลาสจากต้นแบบอยู่ใน `global.css`; CTA หลักสีแดง แถบเมนูสีกรม; ทุกหน้าต้องรับมือข้อมูลว่าง (ไม่หารด้วยศูนย์ แสดง "–")
- **กฎซ้ำสองที่:** ตัวตรวจข้อมูล (validators) อยู่ทั้ง `app/src/lib/validators.ts` และ `api/src/lib/validators.ts` ต้องแก้คู่กัน; `AUTH_SECRET` ต้องเหมือนกันทั้งเว็บและ API

4.2 API (Fastify)

โค้ด API แบ่งเป็นชั้นชัดเจน เพื่อให้เส้นทางบางและตรรกะทดสอบได้:

ชั้น	ตำแหน่ง	หน้าที่
Routes	`api/src/routes/*` (11 ไฟล์, 94 เส้นทางรวม ingest)	ประกาศเส้นทาง, สคีมา TypeBox (ตรวจข้อมูลเข้า/ออก และสร้าง OpenAPI), เรียก guard สิทธิ์, ส่งต่อไป services
Services	`api/src/services/*`	ตรรกะธุรกิจ: การประเมินสถานะ/แจ้งเตือน (`ops`), 2FA, ส่งอีเมล/LINE, รายงานและ Excel, สรุปรายวัน, บันทึกกิจกรรม, ตรวจ migration
Lib	`api/src/lib/*`	ฟังก์ชันล้วนที่ทดสอบง่าย: TOTP, seal (AES-GCM), validators, paging, loginGuard, schedule (เวลาไทย), auditLabels
Data	`api/src/db.ts`	pg Pool, `withTx` (ทรานแซกชัน), helper `one`/`rows`; SQL เป็นแบบ parameterized ทั้งหมด
Auth	`api/src/auth.ts`	ออก/ตรวจ JWT, `requireRole(pool, minRole)` อ่านผู้ใช้จากฐานข้อมูลทุกคำขอ, ตรวจ API key ของ ingest

ข้อตกลงของ API

- **ข้อผิดพลาด** ใช้รูปแบบเดียว `{ "error": { "code", "message", "fields"? } }` ข้อความเป็นภาษาไทย; ข้อผิดพลาดรายฟิลด์อยู่ใน `fields`
- **แบ่งหน้าแบบ opt-in:** ส่ง `page` (และ `pageSize` ≤ 100) แล้วได้ซอง `{ items, total, page, pageSize, pages, summary? }` ไม่ส่งได้อาร์เรย์เดิม — ใช้กับ vehicles, alerts, charging/history, drivers, users, audit-log

- **อัตราเรียก:** จำกัดรวม 600 คำขอ/นาที/ไอพี
  และเข้มกว่าเป็นรายเส้นทางสำหรับล็อกอิน/2FA/การตั้งค่าความปลอดภัย
- **เอกสาร API** สร้างอัตโนมัติจากสคีมาที่ `/docs` (Swagger UI)
- **IP ผู้เรียก** เชื่อ `X-Forwarded-For` เฉพาะจำนวนชั้นพร็อกซีที่กำหนด (`TRUST_PROXY_HOPS`) เพื่อให้ rate limit และบันทึกกิจกรรมได้ IP จริง

4.3 งานเบื้องหลัง

งานทั้งหมดรันในโปรเซส API ผ่าน `startJobs` แต่ละงานห่อด้วย `step()` แยกกัน งานหนึ่งล้มเหลว (เช่น SMTP ล่ม หรือฐานข้อมูลขาด migration) ถูกบันทึกเป็น error แต่ไม่หยุดงานอื่น โดยเฉพาะการตรวจรถออฟไลน์

งาน	ความถี่	หน้าที่	กลไกกันซ้ำ/ความปลอดภัย
ตรวจรถออฟไลน์	ทุก 60 วินาที	รถที่เงียบเกินเกณฑ์ (ตั้งค่าได้ ค่าเริ่มต้น 30 นาที) → สถานะ "ออฟไลน์" และสร้างแจ้งเตือน	advisory lock ในฐานข้อมูล; ไม่แจ้งซ้ำถ้ามีของเดิมที่ยังไม่รับทราบ; ไม่แตะรถที่ไม่เคยส่งข้อมูล
ส่งแจ้งเตือน LINE/อีเมล	ทุก 15 วินาที	ส่งแจ้งเตือนระดับวิกฤต/เตือนที่ใหม่ (ไม่เกิน 10 นาที) รวมเป็นข้อความเดียวต่อรอบ	จองแถวด้วย `line_notified_at`/`email_notified_at` แบบอะตอมมิก; เคารพสวิตช์ระบบและตัวเลือกรายบุคคล
ส่งรายงานตามตาราง	ตรวจทุก 60 วินาที	ส่งอีเมลสรุปตัวเลขพร้อมแนบไฟล์ Excel ตามตารางรายวัน/สัปดาห์/เดือน (เวลาไทย)	คำนวณ `next_run_at`; ส่งล้มเหลวบันทึก `last_status`/`last_error`
สรุปรายวัน	ถึง 08:00 น. เวลาไทย (ตั้งได้)	อีเมลสรุปสถานะรถ แจ้งเตือนและการชาร์จของเมื่อวาน ถึง admin/manager	จอง `digest_last_date` วันละครั้ง; ไม่ส่งถ้าไม่มีรถ; ส่งไม่สำเร็จเลย = คืนการจอง
ล้างบันทึกกิจกรรมเก่า	วันละครั้ง	ลบแถว audit_log ที่เก่ากว่า `AUDIT_KEEP_DAYS`	เป็นทางเดียวที่ลบแถว audit ได้ (trigger กัน UPDATE)

4.4 การแจ้งเตือนหลายช่องทาง

การแจ้งเตือน	เกิดเมื่อ	ผู้รับ	การควบคุม
อีเมลแจ้งเตือนกองยาน	แจ้งเตือนวิกฤต/เตือนใหม่	admin/manager ที่ active	สวิตช์ระบบ + `alertEmail` รายบุคคล
LINE	แจ้งเตือนวิกฤต/เตือนใหม่	กลุ่ม/บัญชีที่ตั้ง (`LINE_TO`)	สวิตช์ระบบ + ต้องมี token
สรุปรายวัน	ทุกเช้า	admin/manager ที่ active	สวิตช์ระบบ + `dailyDigest` รายบุคคล
รายงานตามตาราง	ถึงเวลาตามตาราง	รายชื่ออีเมลในตาราง (≤10)	จัดการโดย manager ขึ้นไป
ลืมรหัสผ่าน / คำเชิญ	ผู้ใช้ขอ / admin เชิญ	เจ้าของอีเมลนั้น	จำเป็นต่อการใช้งาน (ไม่มีสวิตช์)
เตือนล็อกอินผิดซ้ำ	รหัสผ่านผิด ≥5 หรือ 2FA ผิด ≥3 ใน 15 นาที	เจ้าของบัญชีนั้น	`loginFailed` — ปิดต้องยืนยันรหัสผ่าน; พักส่ง 1 ชม.
เตือนเครือข่ายใหม่	ล็อกอินสำเร็จจากเครือข่ายที่ไม่เคยเห็นใน 90 วัน	เจ้าของบัญชีนั้น	`newNetwork` — ปิดต้องยืนยันรหัสผ่าน

> ถ้าไม่ตั้ง `SMTP_URL` การส่งอีเมลทุกประเภททำงานแบบ "ปิด" (ไม่ส่ง ไม่ error)
> ผู้ดูแลยังสร้างลิงก์คำเชิญ/รีเซ็ตรหัสเองได้จากหน้าตั้งค่า การส่งอีเมลลืมรหัสผ่านทำในพื้นหลังและเงียบเมื่อล้มเหลวโดยตั้งใจ (กันการเดาว่าอีเมลใดมีในระบบ) จึงต้องทดสอบ SMTP ตรงตอนติดตั้ง

4.5 การสำรองและกู้คืน

1. **สำรองรายวัน 02:00 น. (เวลาไทย):** `pg_dump` รูปแบบ custom บีบอัด เขียนเป็นไฟล์ชั่วคราวแล้วเปลี่ยนชื่อ ตรวจด้วย `pg_restore --list` และต้องมีตารางข้อมูลครบพอสมควรจึงนับว่าสำเร็จ
2. **เก็บในเครื่อง:** `./backups` เก็บ 14 วันแต่ไม่น้อยกว่า 3 ไฟล์ (ไม่เข้ารหัส สิทธิ์ 0600)
3. **เข้ารหัสและพัก:** `offsite.sh` เข้ารหัสด้วยกุญแจสาธารณะ age (ไม่เข้ารหัส = ไม่ส่ง) ไปโฟลเดอร์พัก `/srv/evmonitor-offsite` ส่งย้อนไฟล์ที่ยังไม่มี ตรวจขนาด เก็บ 30 วัน (≥5 ไฟล์)
4. **ดึงลงเครื่องผู้ดูแล:** งานตามเวลาบน Windows รัน `pull-offsite.ps1` ด้วยบัญชี `evpull` ที่ทำได้แค่ SFTP แบบอ่านอย่างเดียว ตรวจขนาดและหัวไฟล์ age ก่อนรับ
5. **ทดสอบกู้:** `verify-offsite-local.ps1` ถอดรหัสด้วยกุญแจส่วนตัวและนับตาราง; `restore.sh` กู้ลงฐานข้อมูลใหม่ (กู้ทับของจริงต้องตั้งตัวแปรยืนยันและหยุด api/web ก่อน)

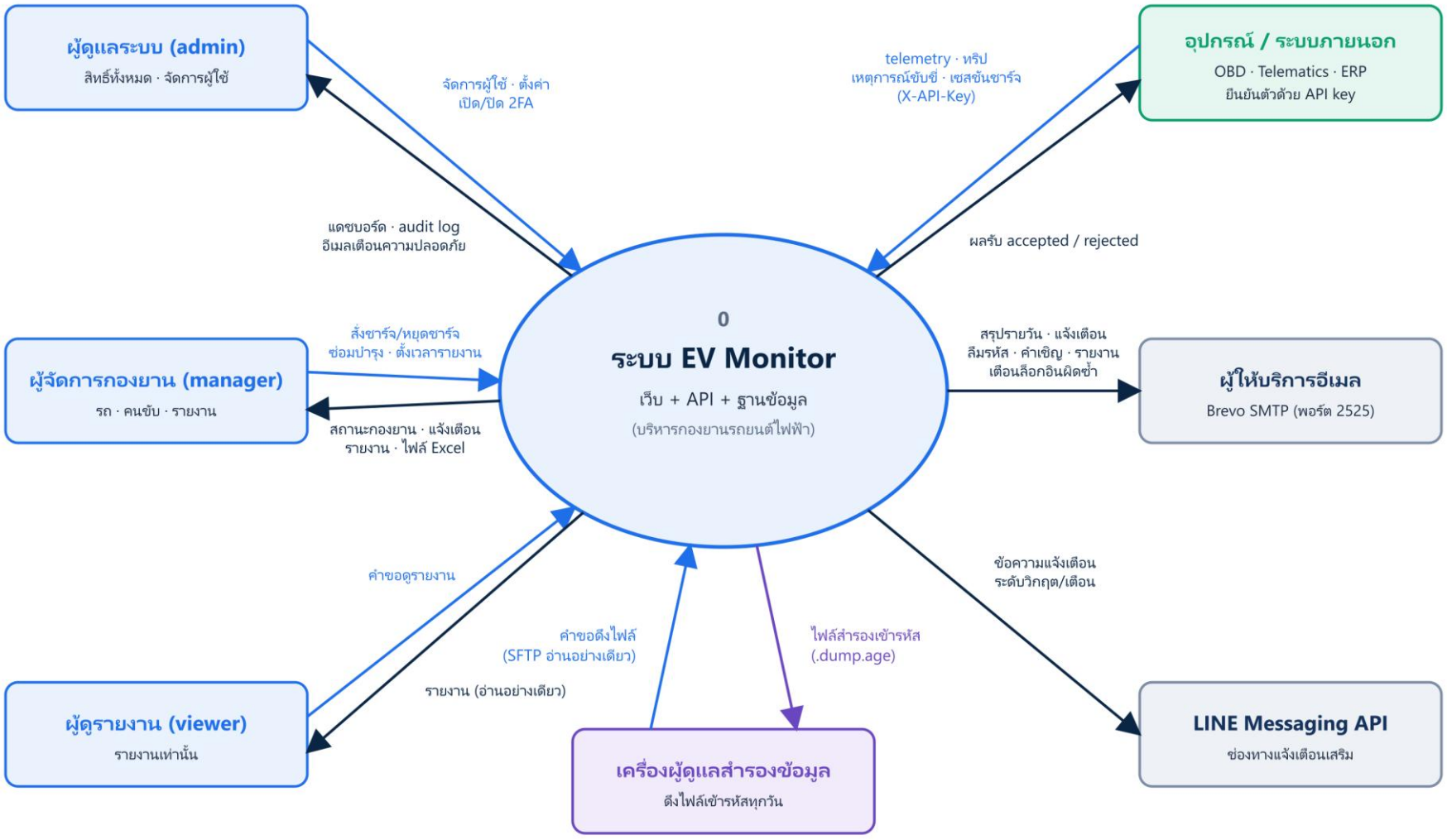
> กุญแจถอดรหัส age ส่วนตัวต้องมีสำเนาแยกอยู่ที่ปลอดภัย ถ้าหายหรือเครื่องเสียพร้อมกับไฟล์ที่ดึงมา ไฟล์สำรองทั้งหมดจะกู้ไม่ได้และไม่มีทางแก้ไข

5. การไหลของข้อมูล (Data Flow)

บทนี้อธิบายว่าข้อมูลเข้า ถูกประมวลผล เก็บ และออกจากระบบอย่างไร ด้วยแผนภาพการไหลของข้อมูล (DFD) สองระดับ แล้วเจาะลงเป็นลำดับขั้นของเหตุการณ์สำคัญ 4 เรื่อง

สัญลักษณ์	ความหมาย
วงรี / กล่องมุมมน **P**	กระบวนการ (Process) ที่แปลงหรือย้ายข้อมูล
กล่องเปิดด้านข้าง **D**	ที่เก็บข้อมูล (Data store) เช่น ตารางในฐานข้อมูล หรือไฟล์สำรอง
กล่องสี่เหลี่ยม **E**	ผู้ใช้หรือระบบภายนอก (External entity)
ลูกศร / **F1–F21**	กระแสข้อมูล (Data flow) ระดับ 1 ใช้หมายเลขกำกับแล้วอธิบายในตาราง

แผนภาพ DFD ระดับ 0 (Context Diagram)



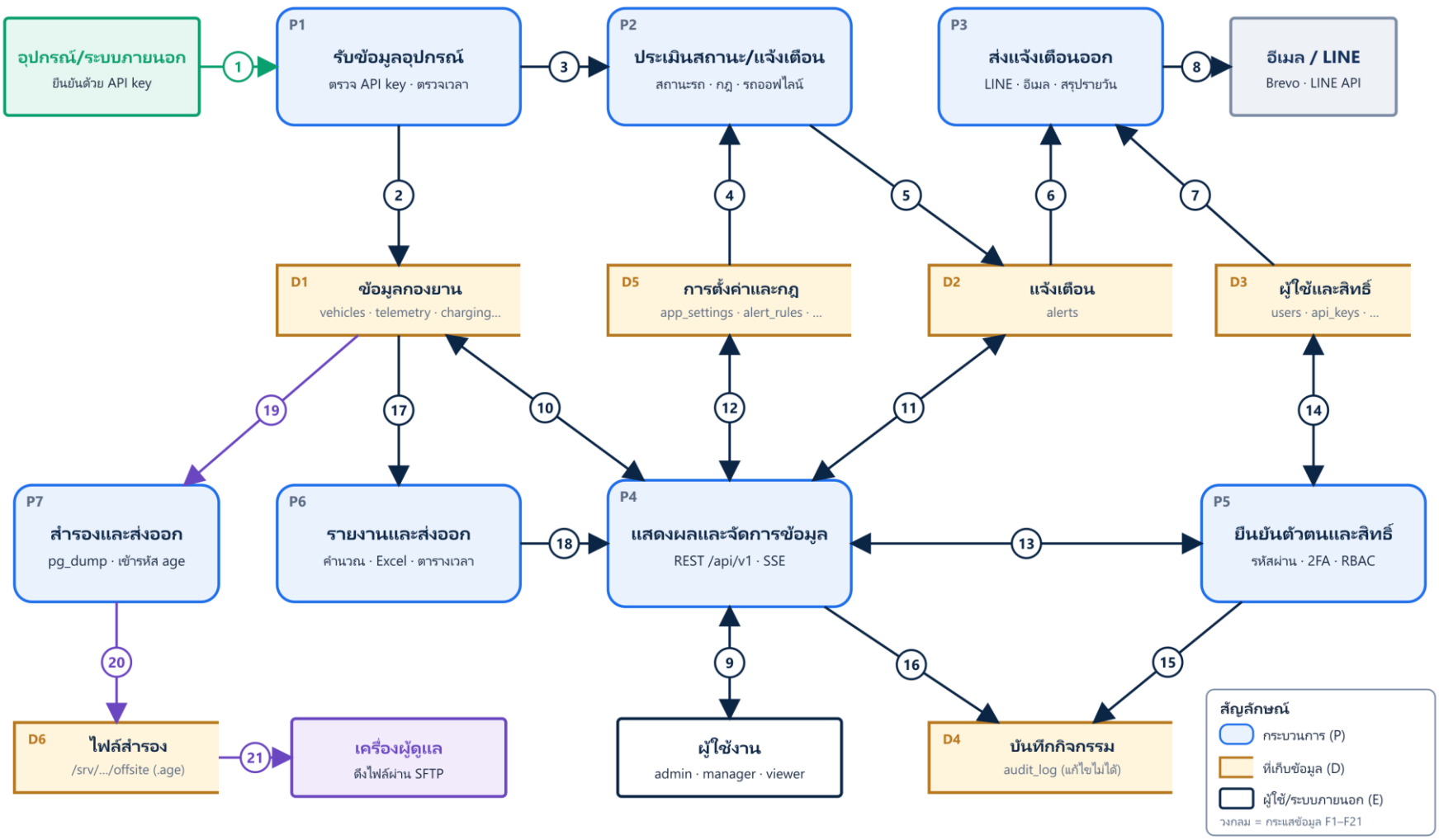
รูปที่ 2 แผนภาพกระแสข้อมูลระดับ 0 — ระบบเป็นกล่องเดียวกับฝ่ายภายนอก 7 ฝ่าย

5.1 DFD ระดับ 0: กระแสข้อมูลเข้า-ออกระบบ

รูปที่ 2 มองระบบเป็นกล่องเดียว ตารางสรุปข้อมูลที่แต่ละฝ่ายส่งเข้าและรับออก

ฝ่ายภายนอก	ข้อมูลเข้าสู่ระบบ	ข้อมูลออกจากระบบ
ผู้ดูแลระบบ	จัดการผู้ใช้/เชิญ/รีเซ็ต 2FA, ตั้งค่าระบบ, เปิด-ปิดนโยบาย 2FA, API key	แดชบอร์ด, บันทึกกิจกรรม, อีเมลเตือนความปลอดภัย (ล็อกอินผิด/เครือข่ายใหม่)
ผู้จัดการกองยาน	เพิ่ม/แก้รถ คนขับ สถานี, สั่งชาร์จ/หยุดชาร์จ, ซ่อมบำรุง, ตั้งเวลาส่งรายงาน	สถานะกองยาน, แจ้งเตือน, รายงานและไฟล์ Excel, สรุปรายวัน
ผู้ดูรายงาน	คำขอดูรายงาน	รายงานแบบอ่านอย่างเดียว
อุปกรณ์/ระบบภายนอก	telemetry, ทริป, เหตุการณ์ขับขี่, เซสชันชาร์จ, ข้อมูลพลังงาน (ยืนยันด้วย API key)	ผลรับ: จำนวนที่ยอมรับ (accepted) และรายการที่ปฏิเสธพร้อมเหตุผล (rejected)
ผู้ให้บริการอีเมล (Brevo)	—	อีเมลทุกประเภท: สรุปรายวัน แจ้งเตือน ลืมรหัส/คำเชิญ รายงาน เตือนความปลอดภัย
LINE Messaging API	—	ข้อความแจ้งเตือนระดับวิกฤต/เตือน
เครื่องผู้ดูแลสำรองข้อมูล	คำขอดึงไฟล์ (SFTP อ่านอย่างเดียว)	ไฟล์สำรองเข้ารหัส (`.dump.age`)

แผนภาพ DFD ระดับ 1



รูปที่ 3 แผนภาพกระแสข้อมูลระดับ 1 — กระบวนการ P1–P7 ที่เก็บข้อมูล D1–D6 และกระแส F1–F21

5.2 DFD ระดับ 1: กระบวนการภายในระบบ

กระบวนการ (P) และที่เก็บข้อมูล (D)

รหัส	ชื่อ	หน้าที่ / ตำแหน่งในโค้ด
P1	รับข้อมูลอุปกรณ์	ตรวจ API key (เทียบ sha256), ตรวจรูปแบบและเวลา (ไม่เกินอนาคต 5 นาที), บันทึก — `routes/ingest.ts`
P2	ประเมินสถานะ/แจ้งเตือน	คำนวณสถานะรถ 5 แบบ (วิ่ง/ชาร์จ/จอด/แบตต่ำ/ออฟไลน์) เทียบเกณฑ์และกฎ สร้างแจ้งเตือนโดยกันซ้ำ; งานตรวจรถออฟไลน์ — `services/ops.ts`, `jobs.ts`
P3	ส่งแจ้งเตือนออก	ส่ง LINE/อีเมล สรุปรายวัน รายงานตามตาราง — `lineNotify`, `emailNotify`, `dailyDigest`, `reportMail`
P4	แสดงผลและจัดการข้อมูล	REST API ทั้งหมดที่เว็บใช้ และสตรีม SSE — `routes/*`
P5	ยืนยันตัวตนและสิทธิ์	ล็อกอิน/2FA/คำเชิญ/รีเซ็ตรหัส/RBAC/นโยบาย 2FA — `routes/auth.ts`, `auth.ts`, `twofactor.ts`
P6	รายงานและส่งออก	คำนวณพลังงาน ต้นทุน คาร์บอน TCO, สร้าง Excel — `services/report*.ts`
P7	สำรองและส่งออกไฟล์	pg_dump ตรวจ เข้ารหัส age พักไฟล์ — `db/backup/*.sh`
D1	ข้อมูลกองยาน	vehicles, drivers, stations, vehicle_telemetry, trips, driving_events, charging_sessions, maintenance_tasks, energy_*, ice_vehicles, tco_items
D2	แจ้งเตือน	alerts (พร้อมคอลัมน์จองการส่ง LINE/อีเมล)
D3	ผู้ใช้และสิทธิ์	users, password_resets, user_recovery_codes, api_keys
D4	บันทึกกิจกรรม	audit_log (แก้ไขไม่ได้)
D5	การตั้งค่าและกฎ	app_settings, alert_rules, notification_channels, integrations, report_config, report_schedules
D6	ไฟล์สำรอง	ไฟล์ `.dump.age` ในโฟลเดอร์พัก และสำเนาที่เครื่องผู้ดูแล

กระแสข้อมูล F1–F21

F	จาก → ไป	ข้อมูล
1	อุปกรณ์ → P1	telemetry (SOC ความเร็ว ตำแหน่ง อุณหภูมิ), ทริป, เหตุการณ์ขับขี่, เซสชันชาร์จ พร้อม X-API-Key
2	P1 → D1	แถว vehicle_telemetry และค่าล่าสุดของรถ (SOC ตำแหน่ง ความเร็ว last_seen_at)
3	P1 → P2	รถที่สถานะ/ระดับแบตเปลี่ยน ต้องประเมินกับเกณฑ์
4	D5 → P2	เกณฑ์แบตต่ำ/วิกฤต เกณฑ์ออฟไลน์ และกฎแจ้งเตือนที่เปิดอยู่
5	P2 → D2	แจ้งเตือนใหม่ (ระดับ ประเภท ข้อความ รถ) โดยไม่ซ้ำกับที่ยังไม่รับทราบ
6	D2 → P3	แจ้งเตือนวิกฤต/เตือนที่ยังไม่ส่ง (งานทุก 15 วินาที)
7	D3 → P3	ผู้รับ (admin/manager ที่ active) และตัวเลือกรับอีเมลรายบุคคล
8	P3 → อีเมล/LINE	ข้อความแจ้งเตือน สรุปรายวัน รายงาน (พร้อม Excel)
9	ผู้ใช้ ↔ P4	คำขอ HTTP จากเว็บ ↔ JSON/สตรีม SSE
10	D1 ↔ P4	อ่านและแก้ข้อมูลกองยาน
11	D2 ↔ P4	อ่านรายการแจ้งเตือน และบันทึกการรับทราบ
12	D5 ↔ P4	อ่านและแก้ค่าตั้งระบบ กฎ ตารางส่งรายงาน
13	P4 ↔ P5	P4 ถาม P5 ว่าคำขอนี้ใคร สิทธิ์อะไร; P5 ตอบ (หรือปฏิเสธ 401/403)

F	จาก → ไป	ข้อมูล
14	D3 ↔ P5	ผู้ใช้ รหัสผ่านแฮช ความลับ 2FA (เข้ารหัส) รหัสสำรอง
15	P5 → D4	เหตุการณ์ความปลอดภัย: ล็อกอินสำเร็จ/ผิด/ถูกบล็อก 2FA ผิด ตอบรับคำเชิญ รีเซ็ตรหัส
16	P4 → D4	ทุกคำขอแก้ข้อมูลที่สำเร็จ (ผู้ทำ เป้าหมาย IP ชื่อฟิลด์ — ไม่เก็บค่า)
17	D1 → P6	ข้อมูลพลังงาน ระยะทาง ต้นทุน เพื่อคำนวณรายงาน
18	P6 → P4	ผลรายงาน/ไฟล์ Excel ส่งผ่าน REST
19	D1 (ฐานข้อมูลทั้งชุด) → P7	pg_dump ทั้งฐานข้อมูล
20	P7 → D6	ไฟล์สำรองเข้ารหัสพักในโฟลเดอร์พัก
21	D6 → เครื่องผู้ดูแล	ดึงผ่าน SFTP แบบอ่านอย่างเดียว

> ในระดับ 1 กระบวนการ P5 ยังอ่านค่า `app_settings` (นโยบายบังคับ 2FA) และ P6 อ่าน `report_config`/`ice_vehicles` ซึ่งไม่ได้วาดเป็นเส้นแยกเพื่อไม่ให้แผนภาพซับซ้อนเกินไป

5.3 ลำดับขั้นของเหตุการณ์สำคัญ

(ก) จาก telemetry สู่แจ้งเตือนและการส่งออก

ขั้น	ผู้กระทำ	รายละเอียด
1	อุปกรณ์	`POST /api/v1/ingest/telemetry` พร้อม `X-API-Key` และรายการ readings
2	api (P1)	เทียบ hash ของ key กับ `api_keys` (ยังไม่ถูกเพิกถอน) ตรวจสคีมา แล้วเปิดทรานแซกชันเดียวสำหรับทั้งชุด
3	api (P1)	แต่ละรายการล็อกแถวรถ (`for update`): ไม่พบรถ/เวลาอยู่ในอนาคตเกิน 5 นาที → ใส่รายการ rejected พร้อมเหตุผล; ที่ผ่าน → เพิ่ม `vehicle_telemetry`, อัปเดต `vehicles` (SOC ตำแหน่ง ความเร็ว), คำนวณสถานะใหม่
4	api (P2)	ถ้ากฎ "แบตต่ำ" เปิดอยู่และ SOC เพิ่ง **ข้าม** เกณฑ์ลงมา → สร้างแจ้งเตือน (วิกฤตหรือเตือน) ไม่สร้างซ้ำถ้ายังมีของเดิมที่ยังไม่รับทราบ; ถ้ากฎ "ความเร็ว" เปิดอยู่และความเร็วเพิ่งเกินเกณฑ์ → แจ้งเตือนและบันทึก `driving_events` ชนิด speeding
5	api	commit; ตอบ `{accepted, rejected[]}`; เหตุการณ์ "change" ถูกส่งไปทุกสตรีม SSE
6	เว็บ	ได้รับสัญญาณ → หน้าที่ติดตามโหลดข้อมูลใหม่ผ่าน API ตามสิทธิ์ผู้ใช้
7	api (P3)	งานทุก 15 วินาทีจอง `alerts` ที่ยังไม่ส่งและอายุไม่เกิน 10 นาที → ส่ง LINE/อีเมลถึงผู้รับที่เลือกรับ

(ข) การเข้าสู่ระบบสองขั้น (2FA)

ขั้น	ผู้กระทำ	รายละเอียด
1	ผู้ใช้	กรอกอีเมล/รหัสผ่านที่ `/login` → `POST /auth/login`
2	api	ตรวจจำกัดการเดา (รายไอพี และรายบัญชี) → ตรวจรหัสด้วย bcrypt ในฐานข้อมูล (อีเมลที่ไม่มีก็ทำ bcrypt เปล่าเท่ากัน เพื่อให้เวลาตอบเท่ากัน)
3	api	ถ้าบัญชีไม่เปิด 2FA → ออก cookie `ev_session` ทันที; ถ้าเปิด → **ไม่ออก cookie** ส่งโทเคนชั่วคราว (อายุ 5 นาที ใช้เป็นเซสชันไม่ได้) และยังไม่บันทึกเวลาเข้าใช้
4	ผู้ใช้	กรอกรหัส 6 หลักจากแอป หรือรหัสสำรอง → `POST /auth/login/2fa`
5	api	ตรวจ TOTP (คลาด ±1 ช่วง, ใช้ช่วงเวลาเดิมซ้ำไม่ได้ด้วยการอัปเดตแบบมีเงื่อนไข) หรือรหัสสำรอง (ใช้ได้ครั้งเดียว); ผิดเกิน 10 ครั้ง/15 นาที → ถูกบล็อก
6	api	ผ่าน → ออก cookie บันทึก `auth.login` และเทียบเครือข่ายกับประวัติ 90 วัน (ใหม่ → ส่งอีเมลเตือน); ผิด → บันทึก `auth.2fa_failed` และอาจส่งเตือน

(ค) คำขอแก้ข้อมูลหนึ่งครั้ง

1. เบราว์เซอร์ส่งคำขอไปเว็บ → เว็บส่งต่อ API พร้อม cookie (หลังเก็บกวาด `X-Forwarded-For`)
2. `requireRole` ตรวจ JWT แล้วอ่านผู้ใช้จากฐานข้อมูล (ต้อง active, `session_version` ตรง, บทบาทพอ, และถ้าเป็นผู้ดูแลที่ติดนโยบาย 2FA ต้องเปิด 2FA แล้ว)
3. สคีมา TypeBox ตรวจข้อมูล; ผิด → 400/422 พร้อมข้อความรายฟิลด์
4. ทำงานในทรานแซกชัน (กรณีสำคัญ เช่น ลดสิทธิ์ผู้ดูแล ล็อกแถวเพื่อให้เหลือ admin อย่างน้อย 1 คน)
5. hook `onSend` เขียนแถว `audit_log` (ผู้ทำ เป้าหมาย IP ชื่อฟิลด์) **ก่อน** ตอบผู้ใช้
6. ส่งเหตุการณ์ "change" ไปสตรีม SSE เพื่อให้หน้าอื่นที่เปิดอยู่รีเฟรชเอง

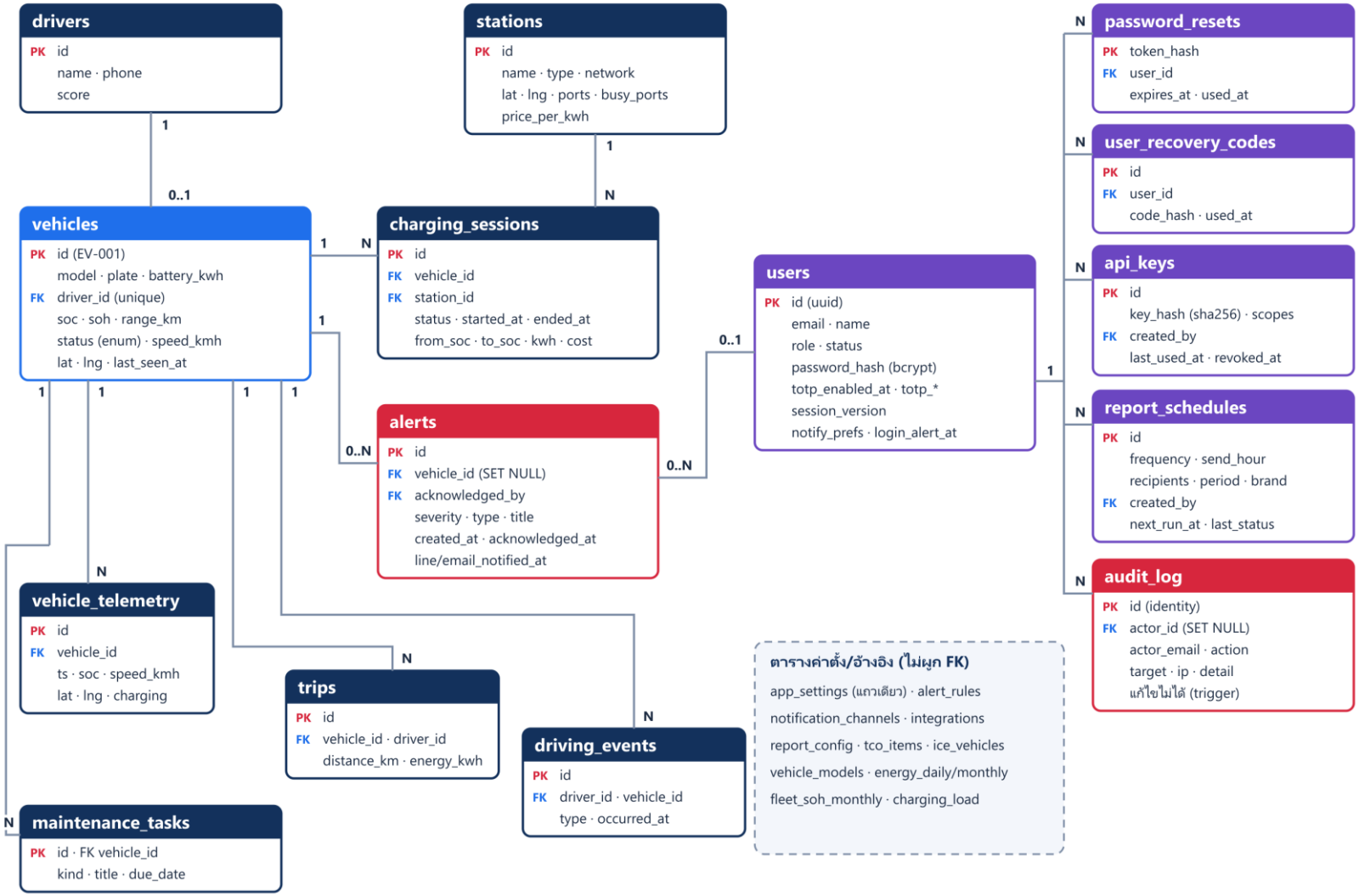
(ง) การสำรองและดึงออกนอกเครื่อง

1. container `backup` รัน `pg_dump` ตี 2 → ตรวจไฟล์ → เก็บใน `./backups`
2. `offsite.sh` เข้ารหัสไฟล์ที่ยังไม่มีในโฟลเดอร์พักด้วยกุญแจสาธารณะ age ตรวจขนาด แล้วตั้งสิทธิ์ให้ผู้ดึงอ่านได้ และบันทึกเวลาสำเร็จล่าสุด (healthcheck ใช้)
3. งานตามเวลาบนเครื่องผู้ดูแล (09:30 น. ทุกวัน) รัน `pull-offsite.ps1` → เชื่อมต่อด้วย SFTP แบบอ่านอย่างเดียว ตรวจ host key แบบเคร่งครัด ดึงเฉพาะไฟล์ใหม่ ตรวจขนาดและหัวไฟล์
4. เป็นระยะ: `verify-offsite-local.ps1` ถอดรหัสด้วยกุญแจส่วนตัวใน Docker แล้วนับตารางเพื่อพิสูจน์ว่ากู้ได้

6. การออกแบบฐานข้อมูล

ฐานข้อมูลเป็น PostgreSQL 16 สคีมาเดียว (`public`) 27 ตาราง schema ฉบับล่าสุดอยู่ที่ `db/init/01_schema.sql` (ใช้ตอนสร้างฐานข้อมูลใหม่) และทุกการเปลี่ยนแปลงหลังจากนั้นมีไฟล์ใน `db/migrations/` สำหรับฐานข้อมูลที่รันอยู่

6.1 แผนภาพ ER (Entity-Relationship)



รูปที่ 4 แผนภาพ ER ของตารางหลัก (ตารางอ้างอิงและตารางรายงานแสดงเป็นกลุ่มในหัวข้อ 6.2)

6.2 กลุ่มตาราง

กลุ่ม	ตาราง	หน้าที่
กองยาน	vehicles, vehicle_models, drivers	ข้อมูลหลักของรถ (รหัส EV-xxx ข้อความ) รุ่นรถ และคนขับ (รถ 1 คัน ผูกคนขับประจำได้ 1 คน)
ข้อมูลจากอุปกรณ์	vehicle_telemetry, trips, driving_events	ประวัติสถานะรถรายครั้ง ทริป และเหตุการณ์ขับขี่
การชาร์จและพลังงาน	stations, charging_sessions, charging_load, energy_daily, energy_monthly, fleet_soh_monthly	สถานีและเซสชันชาร์จ โหลดไฟรวม พลังงานรายวัน/เดือน และสุขภาพแบตเฉลี่ยรายเดือน
แจ้งเตือนและซ่อมบำรุง	alerts, alert_rules, notification_channels, maintenance_tasks	แจ้งเตือน กฎและช่องทาง งานซ่อมบำรุง
ผู้ใช้และความปลอดภัย	users, password_resets, user_recovery_codes, api_keys, audit_log	บัญชี คำเชิญ/รีเซ็ตรหัส รหัสสำรอง 2FA, API key ของอุปกรณ์ และบันทึกกิจกรรม
ตั้งค่าและรายงาน	app_settings, integrations, report_config, report_schedules, ice_vehicles, tco_items	ค่าตั้งองค์กร (แถวเดียว `id = 1`) สถานะการเชื่อมต่อ สมมติฐานรายงาน ตารางส่งรายงาน รถสันดาปเปรียบเทียบ และรายการ TCO

6.3 ชนิดค่า (enum)

ชนิด	ค่า
vehicle_status	driving, charging, parked, low, offline (5 สถานะของรถ)
alert_severity	critical, warning, info (วิกฤต / เตือน / ข้อมูล)
alert_type	battery, charging, device, maint, driving, geofence
user_role	admin, manager, viewer
user_status	active, invited, disabled
session_status	active, completed, stopped
station_type	depot, public
driving_event_type	harsh_brake, speeding, harsh_accel, long_idle
maintenance_kind	service, software, battery

6.4 ข้อกำหนดและกลไกในฐานข้อมูล

- **คีย์:** รถ/คนขับ/สถานีใช้รหัสข้อความที่อ่านได้ (เช่น `EV-001` มี check รูปแบบ) ผู้ใช้ใช้ `uuid` ตารางที่เกิดต่อเนื่องใช้ `bigint identity`
- **FK และการลบ:** ข้อมูลลูกของรถลบตามรถ (`CASCADE`); แจ้งเตือนและบันทึกกิจกรรมอ้างอิงแบบ `SET NULL` เพื่อให้ประวัติอยู่ต่อแม้ลบรถ/ผู้ใช้ (บันทึกกิจกรรมเก็บอีเมลผู้ทำเป็นสำเนา)
- **ความลับ:** รหัสผ่านเป็น bcrypt (pgcrypto); API key และโทเคนเชิญ/รีเซ็ตเก็บเฉพาะ sha256; ความลับ 2FA เก็บแบบเข้ารหัส AES-256-GCM; รหัสสำรอง 2FA เก็บเป็น hash
- **`audit_log` แก้ไขไม่ได้:** trigger ปฏิเสธ UPDATE ทุกกรณีเว้นกรณีเดียวที่ FK เคลียร์ `actor_id` ตอนลบผู้ใช้ (คอลัมน์อื่นต้องคงเดิมทุกค่า)
- **`app_settings` แถวเดียว:** มี check `id = 1` เก็บทั้งค่าองค์กร เกณฑ์ ช่องทางแจ้งเตือน นโยบายบังคับ 2FA และวันที่ส่งสรุปล่าสุด

- **เวลา:** ใช้ `timestamptz` ทั้งหมด; ฐานข้อมูลตั้ง timezone Asia/Bangkok; การนับ "เมื่อวาน" และ "วันนี้" ใช้เวลาไทย
- **trigger `set_updated_at`** อัปเดตคอลัมน์ `updated_at` ของตารางหลักอัตโนมัติ

6.5 การจัดการ schema และ migration

ไฟล์	การเปลี่ยนแปลง
001_invite_tokens	โทเคนคำเชิญผู้ใช้
002_password_reset	ตาราง `password_resets` และการรีเซ็ตรหัส
003_report_schedules	ตารางตั้งเวลาส่งรายงาน
004_alert_line_notified	คอลัมน์จองการส่ง LINE ใน `alerts`
005_alert_email_notified	คอลัมน์จองการส่งอีเมลใน `alerts`
006_user_disabled	ค่า `disabled` ของ `user_status`
007_two_factor	คอลัมน์ TOTP ใน `users` และ `user_recovery_codes`
008_require_admin_2fa	นโยบายบังคับ 2FA ผู้ดูแลใน `app_settings`
009_audit_log	ตาราง `audit_log` พร้อม trigger แก้ไขไม่ได้
010_login_alert	`users.login_alert_at` (ช่วงพักการเตือนล็อกอินผิด)
011_notify_prefs	`users.notify_prefs` (เลือกรับอีเมลรายบุคคล)
012_daily_digest	`app_settings.digest_last_date` (จองสิทธิ์ส่งสรุปรายวัน)

- **กติกา:** เปลี่ยน schema ต้องแก้ `db/init/01_schema.sql` และเพิ่มไฟล์ migration คู่กัน (init รันเฉพาะตอน volume ว่าง) migration เขียนให้รันซ้ำได้ปลอดภัย
- **ตรวจตอนเริ่ม API:** `schemaCheck` เทียบคอลัมน์/ตารางที่โค้ดต้องใช้ ถ้าขาดจะบันทึก error ระบุชื่อไฟล์ migration ที่ต้องรัน (ไม่เช่นนั้นฟีเจอร์ที่เกี่ยวข้องพังเงียบ ๆ ตอนมีคนใช้) — เมื่อเพิ่ม migration ที่โค้ดพึ่งพา ต้องเพิ่มรายการใน `REQUIRED_SCHEMA` ด้วย
- **ติดตั้งใหม่:** image `db` ฝัง `db/init` ไว้ตอน build จึงต้อง build ใหม่ก่อนสร้างฐานข้อมูลหลังแก้ schema

7. การออกแบบ API

7.1 ข้อตกลงทั่วไป

หัวข้อ	ข้อกำหนด
ฐานเส้นทาง	`/api/v1` · ข้อมูลเป็น JSON (UTF-8) · เวลาเป็น ISO 8601 (UTC) แสดงผลฝั่งเว็บเป็นเวลาไทย
การยืนยันตัวตน	ผู้ใช้: cookie `ev_session` (httpOnly, SameSite=Lax, Secure เมื่อใช้ HTTPS) หรือส่วนหัว `Authorization: Bearer` · อุปกรณ์: ส่วนหัว `X-API-Key` ที่ `/ingest/*` เท่านั้น
สิทธิ์	ทุกเส้นทางที่ต้องล็อกอินผ่าน `requireRole(minRole)` ซึ่งอ่านผู้ใช้จากฐานข้อมูลทุกคำขอ
ตรวจข้อมูลเข้า	สคีมา TypeBox ที่ทุกเส้นทาง; กฎความถูกต้องที่ซับซ้อน (อีเมล รหัสผ่าน ช่วงค่า) ตรวจเพิ่มใน `lib/validators.ts` และโยนข้อผิดพลาดรายฟิลด์
แบ่งหน้า	opt-in ด้วย `page` (`pageSize` ≤ 100) ได้ซอง `{ items, total, page, pageSize, pages, summary? }`; ไม่ส่งได้อาร์เรย์ทั้งหมดเหมือนเดิม
เอกสาร	OpenAPI/Swagger UI ที่ `/docs` สร้างจากสคีมา; ไม่ต้องล็อกอิน (ควรปิดหรือจำกัดเมื่อ API เปิดสู่ภายนอก)
การจำกัดอัตรา	รวม 600 คำขอ/นาที/ไอพี; ล็อกอิน 30/นาที; 2FA และการตั้งค่าความปลอดภัย 10–20/นาที; มีการจำกัดรายบัญชีเพิ่ม

รูปแบบข้อผิดพลาดและรหัสสถานะ

```
{ "error": { "code": "invalid", "message": "ข้อมูลไม่ถูกต้อง",
             "fields": { "email": "รูปแบบอีเมลไม่ถูกต้อง" } } }
```

สถานะ	ความหมายและตัวอย่าง `code`
400 / 422	ข้อมูลไม่ผ่านสคีมา / ไม่ผ่านกฎ (`invalid`) พร้อม `fields`
401	ยังไม่ล็อกอิน/หมดอายุ/ถูกเพิกถอน (`unauthorized`, `invalid_credentials`, `invalid_code`, `invalid_challenge`)
403	สิทธิ์ไม่พอ (`forbidden`) หรือผู้ดูแลยังไม่เปิด 2FA ตามนโยบาย (`two_factor_required`)
404 / 409 / 410	ไม่พบ · ซ้ำหรือขัดแย้ง (เช่น เปิด 2FA ซ้ำ) · ลิงก์/การตั้งค่าหมดอายุ (`expired_invite`, `expired_setup`)
429	เรียกถี่เกินหรือถูกบล็อกชั่วคราวจากการเดา (`rate_limited`)
500	ข้อผิดพลาดภายใน (`internal`) — รายละเอียดอยู่ใน log ไม่ส่งให้ผู้เรียก

7.2 กลุ่มเส้นทาง

กลุ่ม	จำนวน	ตัวอย่างเส้นทาง	สิทธิ์ขั้นต่ำ
ยืนยันตัวตน	15	POST /auth/login · /auth/login/2fa · /auth/logout · GET /auth/me · POST /auth/change-password · /auth/forgot-password · /auth/reset/* · /auth/invite/* · /auth/2fa/{setup,enable,disable,recovery-codes} · PUT /auth/notifications	สาธารณะ (ล็อกอิน/คำเชิญ/รีเซ็ต) · ที่เหลือผู้ล็อกอิน
รถ	6	GET/POST /vehicles · GET/PATCH /vehicles/:id · POST /vehicles/:id/maintenance · POST /maintenance/:id/complete	viewer อ่าน · manager แก้
คนขับ	4	GET/POST /drivers · PATCH /drivers/:id · GET /drivers/events	viewer อ่าน · manager แก้
การชาร์จและสถานี	9	GET /charging/{sessions,history,load} · PATCH …/target · POST …/stop · GET/POST/PATCH/DELETE /stations	viewer อ่าน · manager แก้

กลุ่ม	จำนวน	ตัวอย่างเส้นทาง	สิทธิ์ขั้นต่ำ
แจ้งเตือน	7	GET /alerts, /alerts/stats · POST /alerts/ack-all, /alerts/:id/ack · GET/PATCH /alert-rules · GET /notification-channels	viewer ขึ้นไป
รายงานและพลังงาน	15	GET /reports, /reports/export, /reports/electrification, /energy/*, /sustainability, /battery/insights · /ice-vehicles · /tco · /report-config	viewer อ่าน · manager แก้สมมติฐาน/รถสันดาป/TCO
ตั้งเวลาส่งรายงาน	5	GET/POST /report-schedules · PUT/DELETE /report-schedules/:id · POST …/send-now	manager ขึ้นไป
ตั้งค่า ผู้ใช้ และความปลอดภัย	18	GET/PUT /settings · /org · /integrations · /security/status · PUT /security/2fa-policy · GET /audit-log · /users, /users/invite, /users/:id/{invite-link,reset-link,2fa-reset} · /api-keys	admin เป็นหลัก (บางรายการอ่านได้ manager)
เรียลไทม์	1	GET /stream (SSE)	ผู้ล็อกอิน
สาธารณะ	1	GET /public/overview (ตัวเลขภาพรวมที่ไม่ระบุตัวตน ใช้บนหน้าแรก)	ไม่ต้องล็อกอิน
Ingest	13	ดู 7.3	API key

รวม 94 เส้นทาง (81 เส้นทางของผู้ใช้ + 13 ingest) สิทธิ์ที่ละเอียดของแต่ละเส้นทางดูได้จากเอกสาร OpenAPI ที่ `/docs` ซึ่งสร้างจากโค้ดจึงตรงกับของจริงเสมอ

7.3 Ingest API (อุปกรณ์/ระบบภายนอก)

ยืนยันตัวด้วย `X-API-Key` (เก็บเป็น sha256 ใน `api_keys`, เพิกถอนได้, บันทึกเวลาใช้ล่าสุด)
ผู้ดูแลสร้างและเพิกถอนคีย์ที่หน้าตั้งค่า คีย์แสดงให้เห็นครั้งเดียวตอนสร้าง

เส้นทาง	ใช้เพื่อ
POST /ingest/telemetry	ส่งค่าตรวจวัดเป็นชุด (SOC ความเร็ว ตำแหน่ง odometer อุณหภูมิ) — อัปเดตสถานะรถ สร้างแจ้งเตือนอัตโนมัติ ตอบ `accepted/rejected`
POST /ingest/charging/sessions · PATCH …/:vehicleId · POST …/:vehicleId/complete	เริ่ม อัปเดต และจบเซสชันการชาร์จ (รถหนึ่งคันมีเซสชัน active ได้ครั้งละหนึ่ง)
PUT /ingest/stations/:id/occupancy	จำนวนช่องชาร์จที่ถูกใช้อยู่ของสถานี (สถานีสร้างผ่านหน้าเว็บเท่านั้น ไม่ผ่าน ingest)
PUT /ingest/charging/load	กำลังไฟรวมของ depot ตามช่วงเวลา
POST /ingest/trips · POST /ingest/driving-events	ทริปและเหตุการณ์การขับขี่ (เบรกกะทันหัน เร่ง เร็วเกิน จอดนิ่งนาน)
PUT /ingest/drivers/:id/score · PATCH /ingest/vehicles/:id	คะแนนคนขับ และแก้ข้อมูลรถบางฟิลด์ (เช่น สุขภาพแบต เลขไมล์)
PUT /ingest/energy/daily · PUT /ingest/energy/monthly	ข้อมูลพลังงานรายวัน/เดือน สำหรับรายงาน
POST /ingest/alerts	สร้างแจ้งเตือนจากระบบภายนอก

7.4 เรียลไทม์ (SSE)

`GET /api/v1/stream` ส่งเหตุการณ์ `change` (ไม่มีเนื้อข้อมูล) ทุกครั้งที่มีคำขอแก้ข้อมูลสำเร็จหรืองานตั้งรถออฟไลน์
เบราว์เซอร์เมื่อได้รับสัญญาณจะสั่งให้หน้าที่เปิดอยู่โหลดข้อมูลใหม่ผ่าน API ตามสิทธิ์ของตน
จึงไม่มีข้อมูลไหลผ่านสตรีมและไม่ต้องตรวจสิทธิ์ซ้ำ การออกแบบนี้ตั้งใจให้ใช้กับ API อินสแตนซ์เดียว
(บัสอยู่ในหน่วยความจำ) ถ้าขยายเป็นหลายอินสแตนซ์ต้องย้ายไปใช้ Postgres LISTEN/NOTIFY

8. ความปลอดภัย

ความปลอดภัยออกแบบเป็นชั้น (defense in depth) ให้การผิดพลาดหรือการรั่วในชั้นหนึ่งไม่ทำให้ทั้งระบบเสีย ตารางด้านล่างสรุปมาตรการตามชั้น แล้วเทียบกับภัยคุกคามในหัวข้อ 8.7

8.1 การยืนยันตัวตนและเซสชัน

- **รหัสผ่าน:** แฮชด้วย bcrypt (pgcrypto ในฐานข้อมูล); ต้องยาว 8–128 ตัว มีทั้งตัวอักษรและตัวเลข; **ห้ามใช้รหัสตั้งต้นของข้อมูลเดโม** ทุกช่องทาง (เปลี่ยนรหัส คำเชิญ รีเซ็ต CLI)
- **เซสชัน:** JWT (HS256) ใน cookie `ev_session` แบบ httpOnly, SameSite=Lax, Secure เมื่อเปิด HTTPS; ตัวเลือก "จดจำฉัน" อายุยาวกว่า
- **เพิกถอนทันที:** `users.session_version` เพิ่มเมื่อเปลี่ยน/รีเซ็ตรหัสผ่าน เปิด/ปิด 2FA หรือรีเซ็ต 2FA โดยผู้ดูแล; ทุกคำขออ่านผู้ใช้จากฐานข้อมูลและเทียบเวอร์ชัน การปิดบัญชีหรือเปลี่ยนบทบาทมีผลทันที
- **จำกัดการเดารหัสผ่าน:** ต่อไอพี 30 ครั้ง/นาที และต่อบัญชี 20 ครั้งผิด/15 นาที (ตัวนับหลักไม่ขึ้นกับไอพี); อีเมลที่ไม่มีในระบบก็ทำ bcrypt เปล่าให้เวลาตอบเท่ากัน ป้องกันการเดาว่ามีบัญชีหรือไม่
- **คำเชิญและรีเซ็ตรหัส:** โทเคนสุ่ม 256 บิต เก็บเฉพาะ sha256 ใช้ได้ครั้งเดียว (เชิญ 7 วัน, รีเซ็ต 60 นาที) ลิงก์ใหม่ทำให้ลิงก์เก่าใช้ไม่ได้; หน้าที่มีโทเคนใน URL ตั้ง `Referrer-Policy: no-referrer`

8.2 การยืนยันตัวตนสองขั้น (2FA)

- **TOTP (RFC 6238)** 6 หลัก/30 วินาที คลาดเวลาได้ ±1 ช่วง ใช้ได้กับแอป Authenticator ทั่วไป; ใช้ช่วงเวลาเดิมซ้ำไม่ได้ (การอัปเดตแบบมีเงื่อนไขในฐานข้อมูล กันแม้ส่งพร้อมกัน)
- **ความลับ 2FA** เข้ารหัส AES-256-GCM ด้วยกุญแจที่ได้จาก `AUTH_SECRET` (HKDF แยกตามวัตถุประสงค์) ฐานข้อมูลหลุดอย่างเดียวจึงยังอ่านความลับไม่ได้ ข้อควรรู้: เปลี่ยน `AUTH_SECRET` แล้วต้องรีเซ็ต 2FA ของทุกคน
- **รหัสสำรอง 8 ชุด** (ใช้ได้ครั้งเดียว เก็บเป็น hash) แสดงครั้งเดียวตอนเปิดหรือสร้างใหม่
- **การตั้งค่า/ปิด/สร้างรหัสสำรอง** ต้องยืนยันรหัสผ่านซ้ำ (และรหัสจากแอปสำหรับการปิด/สร้างใหม่) เพื่อไม่ให้เซสชันที่ถูกขโมยเปลี่ยนค่านี้ได้; โทเคนระหว่างตั้งค่าเป็นแบบปิดผนึกไม่เก็บในฐานข้อมูล อายุ 10 นาที
- **ล็อกอินสองขั้น:** ขั้นแรกถูกต้องแล้วยังไม่ออกเซสชัน ได้เพียงโทเคนชั่วคราว 5 นาทีที่ใช้เป็นเซสชันไม่ได้; ผิดเกิน 10 ครั้ง/15 นาทีถูกบล็อก
- **นโยบายบังคับผู้ดูแล:** ผู้ดูแลเปิดสวิตช์ได้เมื่อตนเองเปิด 2FA แล้ว หลังเปิด ผู้ดูแลที่ยังไม่มี 2FA เข้าได้เฉพาะหน้า "บัญชีของฉัน" (API อื่นตอบ 403 `two_factor_required`) — ไม่ล็อกบัญชีถาวร; เครื่องหาย → ผู้ดูแลรีเซ็ตให้ หรือใช้ CLI `reset-2fa`

8.3 การควบคุมสิทธิ์

- **RBAC สามระดับ** (viewer < manager < admin) บังคับที่ API ทุกเส้นทาง ไม่พึ่งการซ่อนปุ่มฝั่งเว็บ
- **ป้องกันล็อกตัวเอง:** ห้ามเปลี่ยนบทบาท/ปิดบัญชีตัวเอง และต้องเหลือ admin ที่ใช้งานอยู่อย่างน้อย 1 คนเสมอ (ล็อกแถวในทรานแซกชัน)
- **API key ของอุปกรณ์** ใช้ได้เฉพาะ `/ingest/*` ไม่ใช่สิทธิ์ผู้ใช้ เพิกถอนได้ทันที

8.4 ความปลอดภัยของเว็บและการสื่อสาร

มาตรการ	รายละเอียด
HTTPS	Caddy ขอและต่ออายุใบรับรอง Let's Encrypt อัตโนมัติ; เปลี่ยน HTTP→HTTPS; HSTS 1 ปี; HTTP/3
CSP แบบเข้ม	`script-src` เฉพาะสคริปต์ที่มี nonce ของคำขอ + `strict-dynamic` (ไม่มี `unsafe-inline`/`unsafe-eval` บน production); `style-src 'self'`; `connect-src`/`font-src` เฉพาะเว็บเรา; `img-src` เพิ่ม data:/blob: (QR 2FA) และ tile.openstreetmap.org; `object-src none`; `frame-ancestors none`
ส่วนหัวอื่น	`X-Frame-Options: DENY`, `X-Content-Type-Options: nosniff`, `Referrer-Policy`, `Permissions-Policy` (ปิดกล้อง/ไมค์/ตำแหน่ง/ชำระเงิน), API ตอบ `Cache-Control: no-store`
IP ผู้เรียก	Caddy เขียนทับ `X-Forwarded-For`; เว็บเก็บกวาดและเหลือค่าเดียว; API เชื่อเฉพาะชั้นพร็อกซีที่กำหนด — ผู้โจมตีปลอม header เพื่อหลบ rate limit ไม่ได้
ฟอนต์ภายใน	ฟอนต์ self-host ผ่าน next/font ไม่เรียกบริการภายนอกตอนใช้งาน (ลดการรั่วของข้อมูลผู้ใช้และตัด origin จาก CSP)
SQL	ทุกคำสั่งเป็น parameterized query; ไม่ต่อสตริงจากข้อมูลผู้ใช้
ไฟร์วอลล์เครื่อง	ufw เปิดเฉพาะ 22/80/443; web/api/db ไม่เปิดสู่ภายนอก; SSH ปิดรหัสผ่านและปิด root ใช้กุญแจกับผู้ใช้ผู้ดูแลเท่านั้น

8.5 บันทึกกิจกรรมและการแจ้งเตือนความผิดปกติ

- **บันทึกกิจกรรม (`audit_log`):** ทุกคำขอแก้ข้อมูลที่สำเร็จโดยผู้ที่ล็อกอิน ถูกบันทึกอัตโนมัติ (ผู้ทำ เป้าหมาย IP เวลา และ **เฉพาะชื่อฟิลด์** ไม่เก็บรหัสผ่าน/โทเคน/รหัส 2FA) พร้อมเหตุการณ์ล็อกอินสำเร็จ/ผิด/ถูกบล็อก 2FA ผิด ตอบรับคำเชิญ และรีเซ็ตรหัส; แก้ไขไม่ได้ด้วย trigger; ดูได้เฉพาะ admin ที่ตั้งค่า > บันทึกกิจกรรม; เก็บ 365 วัน
- **เตือนเจ้าของบัญชี:** ล็อกอินผิดซ้ำ, 2FA ผิดซ้ำ (บ่งชี้ว่ารหัสผ่านอาจรั่ว), และเข้าสู่ระบบสำเร็จจากเครือข่ายที่ไม่เคยเห็นใน 90 วัน (IPv4 เทียบ /24, IPv6 เทียบ /64) — ส่งเฉพาะบัญชีที่มีอยู่จริงและทำในพื้นหลัง; ผู้ใช้ปิดได้เองแต่ต้องยืนยันรหัสผ่าน

8.6 ความลับและการเข้ารหัสข้อมูล

ข้อมูล	การเก็บ/ปกป้อง
รหัสผ่านผู้ใช้	bcrypt (cost 10) ในฐานข้อมูล
API key, โทเคนคำเชิญ/รีเซ็ต, รหัสสำรอง 2FA	เก็บเฉพาะ sha256 (ไม่เก็บค่าจริง)
ความลับ TOTP	AES-256-GCM กุญแจจาก `AUTH_SECRET` (HKDF)
`AUTH_SECRET`**, รหัสฐานข้อมูล, SMTP**	ไฟล์ `.env` สิทธิ์ 600 บนเซิร์ฟเวอร์ ไม่เข้า git สุ่มต่อสภาพแวดล้อม
ไฟล์สำรอง	ในเครื่อง: สิทธิ์ 0600 ไม่เข้ารหัส · นอกเครื่อง: age (กุญแจสาธารณะ) เซิร์ฟเวอร์ไม่มีกุญแจถอดรหัส
การส่งอีเมล	STARTTLS บังคับ (`requireTLS`); Brevo จำกัดการใช้ SMTP key เฉพาะ IP ของเซิร์ฟเวอร์

8.7 ภัยคุกคามและมาตรการ

ภัยคุกคาม	มาตรการ
เดารหัสผ่าน (brute force)	จำกัดอัตราต่อไอพี + ต่อบัญชี, bcrypt, 2FA, เตือนเจ้าของบัญชี, บล็อกชั่วคราว
ขโมยเซสชัน/cookie	httpOnly + Secure + SameSite; HSTS; เพิกถอนด้วย `session_version`; เตือนล็อกอินจากเครือข่ายใหม่; การเปลี่ยนค่าความปลอดภัยต้องยืนยันรหัสผ่านซ้ำ

ภัยคุกคาม	มาตรการ
XSS / การฉีดสคริปต์	CSP แบบ nonce ไม่มี inline script; React escape ข้อความ; ไม่มี `dangerouslySetInnerHTML` ที่เป็นสคริปต์
Clickjacking	`frame-ancestors none` + `X-Frame-Options: DENY`
CSRF	SameSite=Lax; คำขอแก้ข้อมูลเป็น JSON ที่ต้องมี cookie และผ่านการตรวจสิทธิ์
SQL injection	parameterized query ทั้งหมด; สคีมาตรวจชนิดข้อมูลเข้า
เดาว่าอีเมลใดมีในระบบ	ตอบเหมือนกันเสมอ, bcrypt เปล่าให้เวลาเท่ากัน, ส่งอีเมลในพื้นหลัง
ปลอม header เพื่อหลบ rate limit	Caddy เขียนทับ `X-Forwarded-For`; เว็บเก็บกวาด; API เชื่อเฉพาะชั้นที่กำหนด (ทดสอบปลอม header แล้วไม่ผ่าน)
ผู้ดูแลถูกยึดบัญชี	2FA บังคับได้ทั้งองค์กร; รหัสสำรอง; ผู้ดูแลอื่นรีเซ็ตได้; ต้องเหลือ admin อย่างน้อย 1 คน
ข้อมูลหาย/แรนซัมแวร์	สำรองรายวัน + สำเนาเข้ารหัสที่เครื่องอื่น (ผู้ดึงอ่านอย่างเดียว) + ทดสอบกู้จริง
ความลับรั่วใน log/บันทึก	บันทึกกิจกรรมเก็บเฉพาะชื่อฟิลด์; log ไม่พิมพ์รหัส; ส่งออกอีเมลไม่มีรหัสผ่าน
ช่องโหว่ใน dependency	`npm audit` ฝั่งเว็บไม่พบช่องโหว่ (production); ฝั่ง API เหลือ `uuid` ผ่าน `exceljs` ระดับกลาง ความเสี่ยงต่ำเพราะช่องโหว่ต้องส่ง buffer เอง ซึ่ง exceljs ไม่ใช้

8.8 สิ่งที่ผู้ดูแลต้องทำเอง

- สร้างผู้ดูแลจริง (`create-admin` ถามรหัสแบบซ่อน) แล้วปิดบัญชีเดโมด้วย `retire-defaults`; เปิด 2FA และบังคับ 2FA ผู้ดูแล
- สุ่ม `AUTH_SECRET`/`POSTGRES_PASSWORD`/`INGEST_API_KEY` ใหม่ต่อสภาพแวดล้อม อย่า commit `.env`
- เก็บสำเนากุญแจถอดรหัส age ไว้ที่แยกจากไฟล์สำรอง และรัน `verify-offsite-local.ps1` เป็นระยะ
- ถอด/จำกัดหน้า `/docs` ถ้า API เปิดสู่ภายนอก, ตรวจ dependency เป็นระยะ (`npm audit`)
- ถ้า IP เซิร์ฟเวอร์เปลี่ยน ต้องอัปเดตรายการ IP ที่อนุญาตของผู้ให้บริการอีเมล มิฉะนั้นอีเมลหยุดส่งเงียบ ๆ

9. การติดตั้งและการปฏิบัติการ

9.1 สภาพแวดล้อม

สภาพแวดล้อม	การรัน	ข้อมูล	หมายเหตุ
พัฒนา/เดโมในเครื่อง	`docker compose --profile demo up --build -d`	ข้อมูลเดโม (`SEED_DEMO=true`) + ตัวจำลอง + Mailpit	ผู้ใช้เดโมใช้รหัสตั้งต้น — ใช้ในเครื่องเท่านั้น
ทดสอบอัตโนมัติ	`cd api && npm test`	ฐานข้อมูลทดสอบแยกที่สร้างใหม่ทุกชุด	ต้องมี PostgreSQL ที่เข้าถึงได้ (ดู `api/README.md`)
Production	`docker compose --profile https up -d --no-build <บริการ>`	กองยานว่าง (`SEED_DEMO=false`) หรือข้อมูลจริง	HTTPS ผ่าน Caddy ต้องมีโดเมนชี้เครื่อง

9.2 โครงสร้างการติดตั้ง production

ใช้งานจริงบนเครื่องเสมือนเดียว (Ubuntu 24.04, 1 vCPU, RAM ราว 0.5 GB + swap 2 GB, ดิสก์ ~9 GB) ที่ `https://monitor.lomo2u.com` แอปอยู่ที่ `/opt/evmonitor` ภายใต้ผู้ใช้ผู้ดูแลที่ไม่ใช่ root

องค์ประกอบ	ค่า/ข้อกำหนด
การเข้าเครื่อง	SSH ด้วยกุญแจเท่านั้น (ปิดรหัสผ่านและปิด root); บัญชีผู้ดูแลมี sudo และอยู่กลุ่ม docker
ไฟร์วอลล์ (ufw)	ขาเข้า: 22/tcp, 80/tcp, 443/tcp, 443/udp; ขาออกอนุญาต (แต่ผู้ให้บริการคลาวด์บล็อก 25/465/587)
พอร์ตแอป	caddy 80/443 สาธารณะ · web 3000 → loopback · api 4000 → loopback · db 5432 → loopback
ข้อมูลถาวร	volume `pgdata` (ฐานข้อมูล), `caddy_data` (ใบรับรอง), `./backups`, `/srv/evmonitor-offsite`
Docker	log หมุนเวียน 10 MB × 3 ไฟล์ต่อ container (`/etc/docker/daemon.json`); ทุกบริการ `restart: unless-stopped`; Docker เริ่มตอนบูต
ใบรับรอง	Let's Encrypt ผ่าน Caddy (HTTP-01 ที่พอร์ต 80) ต่ออายุเอง; ใบรับรองและกุญแจอยู่ใน `caddy_data` ห้ามลบ
อีเมล	Brevo SMTP พอร์ต 2525 (STARTTLS บังคับ); โดเมนผู้ส่งมี SPF/DKIM/DMARC; ขึ้นรายการ IP ที่อนุญาตของ Brevo

> เครื่องที่ RAM ต่ำกว่า 1 GB build Next.js บนเครื่องไม่ได้ จึงใช้วิธี build image บนเครื่องพัฒนาแล้วส่งขึ้นเครื่อง (หัวข้อ 9.4) ถ้าต้องรองรับผู้ใช้พร้อมกันหลายคน แนะนำเพิ่ม RAM เป็น 2 GB ขึ้นไป

9.3 ตัวแปรสภาพแวดล้อม (`.env`)

ตัวแปร	ใช้กับ	ความหมาย	ค่าเริ่มต้น / หมายเหตุ
POSTGRES_PASSWORD	db, api, backup	รหัสผ่านฐานข้อมูล	ต้องตั้ง
AUTH_SECRET	api, web	กุญแจลงนาม JWT และต้นทางกุญแจเข้ารหัส 2FA — ต้องเหมือนกันทั้งสอง; เปลี่ยน = ทุกคนต้องล็อกอินใหม่และ 2FA ใช้ไม่ได้	ต้องตั้ง (สุ่มยาว)
INGEST_API_KEY	api, simulator	คีย์ ingest ตั้งต้น/ใช้กับตัวจำลอง	ไม่บังคับ
SEED_DEMO	db (ตอนสร้างครั้งแรก)	true = ข้อมูลเดโม, false = กองยานว่างสำหรับใช้งานจริง	true

ตัวแปร	ใช้กับ	ความหมาย	ค่าเริ่มต้น / หมายเหตุ
ORG_NAME, FLEET_NAME, ORG_CITY, ORG_LAT, ORG_LNG	db (ตอนสร้างครั้งแรก)	ชื่อองค์กร/กองยาน เมืองและจุดกึ่งกลางแผนที่	ว่าง = ค่าอ้างอิง
WEB_PORT, WEB_BIND	web	พอร์ตและอินเทอร์เฟซที่เปิดเว็บ	3000 / 0.0.0.0 (production ใช้ 127.0.0.1)
DOMAIN, ACME_EMAIL	caddy	โดเมนจริงและอีเมลติดต่อ Let's Encrypt	localhost / ว่าง
APP_BASE_URL	api	ฐานของลิงก์ในอีเมล (คำเชิญ รีเซ็ต รายงาน)	http://localhost:3000
COOKIE_SECURE	api	ตั้ง cookie แบบ Secure — ต้อง true เมื่อใช้ HTTPS	false
TRUST_PROXY_HOPS / TRUST_FORWARDED_FOR	api / web	จำนวนชั้นพร็อกซีที่ API เชื่อ / ให้เว็บใช้ `X-Forwarded-For` ท้ายสุดจาก proxy ของเรา	1 / false (ใช้ true เมื่อมี Caddy)
SMTP_URL, MAIL_FROM, MAIL_MODE	api	การส่งอีเมล (smtp / log / off)	ว่าง = ไม่ส่ง
LINE_CHANNEL_ACCESS_TOKEN, LINE_TO	api	แจ้งเตือนเข้า LINE	ว่าง = ไม่ส่ง
OFFLINE_CHECK_INTERVAL_SECONDS	api	รอบงานเบื้องหลัง (วินาที)	60 (0 = ปิดทั้งหมด)
DIGEST_HOUR_TH	api	ชั่วโมงเวลาไทย (0–19) ที่ส่งสรุปรายวัน	8
AUDIT_KEEP_DAYS	api	จำนวนวันเก็บบันทึกกิจกรรม	365 (ขั้นต่ำ 30)
LOG_LEVEL	api	ระดับ log	info
BACKUP_HOUR_TH, BACKUP_KEEP_DAYS, BACKUP_KEEP_MIN, BACKUP_DIR	backup	เวลาสำรอง (เวลาไทย), จำนวนวัน/ไฟล์ที่เก็บ, โฟลเดอร์	2 / 14 / 3 / ./backups
BACKUP_AGE_RECIPIENTS, OFFSITE_TARGET, OFFSITE_LOCAL_DIR, OFFSITE_KEEP_DAYS/MIN	backup	ส่งออกนอกเครื่องแบบเข้ารหัส (กุญแจสาธารณะ age, ปลายทาง, โฟลเดอร์พัก, ระยะเก็บ)	ว่าง = ปิด
NEXT_PUBLIC_DEMO_LOGIN	web (ตอน build)	เติมอีเมล/รหัสเดโมในฟอร์มล็อกอิน	**ห้ามใช้ใน production**
SIM_INTERVAL_SECONDS, SIM_REVIVE	simulator	ความถี่ส่งข้อมูลจำลอง; true = ปลุกรถที่ออฟไลน์	30 / false

9.4 ขั้นตอนอัปเดตระบบ

1. **สำรองก่อนเสมอ:** `docker compose exec -T backup sh /backup/backup.sh`
2. **build บนเครื่องพัฒนา:** `docker compose build` (ถ้าแก้ schema ต้อง build `db` ด้วย)
3. **ส่งโค้ดและ image:** `git archive HEAD | ssh … tar -x -C /opt/evmonitor` (ไม่เขียนทับ `.env`) และ `docker save … | gzip | ssh … "gunzip | docker load"`
4. **รัน migration ที่ยังไม่เคยรัน** จาก `db/migrations/` ตามลำดับเลข (API จะ log error ระบุไฟล์ที่ขาดถ้าลืม)
5. **เริ่มบริการ ระบุชื่อบริการเสมอ:** `docker compose --profile https up -d --no-build web api` (ไม่ระบุอาจเปิดบริการเดโม/ทดสอบที่ไม่ต้องการ)
6. **ตรวจ:** `docker compose ps` (healthy ทุกตัว), `docker compose logs api` ไม่มี error ระดับ 50, เปิดหน้าล็อกอินและดู console ไม่มี CSP violation, ผู้ใช้ทุกคนต้องล็อกอินใหม่ถ้าเปลี่ยนกลไก session

9.5 สำรองและกู้คืน

ชั้น	ที่เก็บ	การปกป้อง	การเก็บ
1. ในเครื่อง	`./backups/*.dump`	สิทธิ์ 0600 ไม่เข้ารหัส	14 วัน (≥3 ไฟล์)
2. โฟลเดอร์พักเข้ารหัส	`/srv/evmonitor-offsite/*.dump.age`	age (กุญแจสาธารณะ)	30 วัน (≥5 ไฟล์)
3. เครื่องผู้ดูแล	`C:\SC\backups-offsite\*.age`	age; ผู้ดึงอ่านอย่างเดียว; กุญแจส่วนตัวอยู่ที่เครื่องนี้	ไม่ลบอัตโนมัติ

- **RPO ≈ 24 ชั่วโมง** (สำรองแบบ logical วันละครั้ง ไม่ใช่ point-in-time) ถ้าต้องการละเอียดกว่านี้ต้องเปิด WAL archiving
- **กู้คืน:** `restore.sh` กู้ลงฐานข้อมูลใหม่ก่อนเสมอ (ปลอดภัย) กู้ทับของจริงต้องหยุด api/web และตั้งตัวแปรยืนยัน; ไฟล์ `.age` ต้องระบุกุญแจส่วนตัว (`BACKUP_AGE_IDENTITY`)
- **ตรวจสุขภาพ:** container `backup` เป็น unhealthy ถ้าไม่มีไฟล์ใหม่กว่า 26 ชั่วโมง หรือถ้าตั้งส่งออกแล้วแต่ไม่สำเร็จเกินกำหนด

9.6 การเฝ้าระวัง

- **สถานะบริการ:** `docker compose ps` — api/web/db/backup มี healthcheck
- **log:** `docker compose logs <บริการ>` (หมุนเวียนอัตโนมัติ); บรรทัดระดับ 40/50 คือคำเตือน/ข้อผิดพลาด
- **ตรวจ migration ตอนเริ่ม:** log "ฐานข้อมูลยังขาด migration: ..." บอกไฟล์ที่ต้องรัน
- **บันทึกกิจกรรม:** ตรวจการล็อกอินผิด/การเปลี่ยนค่าที่ตั้งค่า > บันทึกกิจกรรม
- **อีเมลล้มเหลวเงียบ ๆ:** การส่งบางประเภท (ลืมรหัสผ่าน) ไม่แจ้ง error ต่อผู้ใช้โดยตั้งใจ ให้ตรวจ SMTP ตรงด้วยสคริปต์ทดสอบ (nodemailer `verify`) หลังเปลี่ยนค่าหรือ IP
- **ทรัพยากร:** `free -m`, `df -h /` เดือนละครั้ง (ดิสก์เหลือต่ำกว่า ~1.5 GB หรือใช้เกิน 80% ควรขยาย)

9.7 ข้อควรรู้เรื่องอีเมลบนคลาวด์

- ผู้ให้บริการคลาวด์ส่วนใหญ่บล็อกพอร์ตส่งอีเมลมาตรฐาน (25/465/587) บนเครื่องใหม่ จึงใช้ผู้ให้บริการที่มีพอร์ตสำรอง (2525/2587)
- ทดสอบด้วยการลอง TCP ไปแต่ละพอร์ตจากเครื่องจริงก่อนเลือกผู้ให้บริการ — ข้อผิดพลาด `ETIMEDOUT` แปลว่าถูกบล็อกที่เครือข่าย ไม่ใช่รหัสผิด; `535` คือรหัสผิด; `525 Unauthorized IP` คือยังไม่ได้อนุญาต IP ที่ผู้ให้บริการ
- ถ้าส่งในนามโดเมนที่มีอีเมลใช้งานอยู่ ให้ **แก้ระเบียน SPF เดิม** (เพิ่ม `include:`) ห้ามสร้าง SPF ซ้ำ (มีได้ระเบียนเดียว) และเพิ่ม DKIM กับ DMARC

10. การทดสอบและประกันคุณภาพ

ชั้นการทดสอบ	วิธี	ขอบเขต
ทดสอบ API (อัตโนมัติ)	node:test + tsx กับ PostgreSQL จริง สร้างฐานข้อมูลใหม่ทุกชุด; 232 รายการ ใน 28 ไฟล์	การยืนยันตัวตน สิทธิ์ 2FA บันทึกกิจกรรม แจ้งเตือนทุกชนิด สรุปรายวัน ตารางรายงาน ส่งออก Excel แบ่งหน้า ingest งานเบื้องหลัง เส้นทางแก้ข้อมูล กรณีกองยานว่าง ตรวจ migration
หน่วยของฟังก์ชันล้วน	เวกเตอร์ทดสอบมาตรฐาน RFC 6238, base32, ปิดผนึก AES-GCM, โทเคน, `ipPrefix`, เวลาไทย	TOTP/seal/โทเคนยืนยันขั้นที่สอง ฯลฯ
ความปลอดภัย	เทสต์ rate limit รายไอพี/รายบัญชี, ปลอม `X-Forwarded-For`, replay รหัส 2FA พร้อมกัน, ผู้ดูแลที่ติดนโยบายถูกจำกัดเฉพาะเส้นทางที่อนุญาต	พฤติกรรมที่เป็นเส้นแบ่งความปลอดภัย
ในเบราว์เซอร์จริง	ตรวจหน้าหลักทุกหน้า (แดชบอร์ด แผนที่ รายงานกราฟ การชาร์จ ตั้งค่า รถ บัญชี) ดู console หา CSP violation ทดสอบมุมมองมือถือ	การแสดงผล การทำงานของฟอร์ม และ CSP
ทดสอบบนระบบจริง	HTTPS ผ่าน Caddy (ใบรับรอง HSTS CSP cookie Secure IP จริง), อีเมลทุกประเภทผ่าน SMTP จริง, SSE ผ่านพร็อกซี, สำรอง→ส่งออก→ดึง→ถอดรหัส→กู้ลงฐานข้อมูลชั่วคราวและเทียบจำนวนแถว, ทดสอบว่าบัญชีดึงข้อมูลลบ/เขียนไม่ได้	การติดตั้งและปฏิบัติการจริง

- **ข้อตกลง:** เพิ่มฟีเจอร์ที่แตะความปลอดภัย/การแจ้งเตือน/ฐานข้อมูลต้องมีเทสต์ และเปิดหน้าจอดู console หา "Content Security Policy" ทุกครั้ง
- **บทเรียนจากการทดสอบจริง:** ปัญหาที่เทสต์อัตโนมัติไม่เจอ แต่พบตอนทดสอบกับของจริง เช่น เข้าด้วย IP แล้วขาด SNI, พอร์ตอีเมลถูกบล็อก, งานเบื้องหลังหนึ่งพังทำให้อื่นหยุด, ค่า `0` ถูกแทนค่าเริ่มต้นเพราะใช้ `||` — แก้และมีเทสต์คุมแล้ว

11. ข้อจำกัด ความเสี่ยง และแนวทางต่อไป

11.1 ข้อจำกัดและความเสี่ยงที่ทราบ

ข้อจำกัด / ความเสี่ยง	ผลกระทบ	แนวทาง
API อินสแตนซ์เดียว (บัส SSE และตัวนับล็อกอินผิดอยู่ในหน่วยความจำ)	รันหลายอินสแตนซ์แล้วเหตุการณ์เรียลไทม์ตกหล่นและการจำกัดการเดานับแยกกัน	ย้ายไป Postgres LIS และเก็บตัวนับในฐานข้
ทรัพยากรเครื่องจริงน้อย (RAM ~0.5 GB, ดิสก์ ~9 GB)	รับผู้ใช้พร้อมกันได้จำกัด build บนเครื่องไม่ได้ ดิสก์อาจเต็มเมื่อข้อมูลโต	เพิ่ม RAM ≥2 GB แล
จุดล้มเหลวเดี่ยว (เครื่องเดียว ฐานข้อมูลเดียว)	เครื่อง/ดิสก์เสียหมายถึงบริการหยุดจนกว่าจะกู้	มีสำรองเข้ารหัสนอกเค ถ้าต้องการดีกว่านี้ใช้ r
ไฟล์สำรองที่ดึงลงเครื่องผู้ดูแลต้องพึ่งเครื่องนั้นเปิดอยู่และกุญแจ age ส่วนตัวอยู่ที่เดียว	เครื่องเสียพร้อมกุญแจ = กู้ไฟล์ที่ดึงมาไม่ได้	ทำสำเนากุญแจแยกที่; (ระบบรองรับ S3-com
ใบรับรองและ IP ที่ผู้ให้บริการอีเมลอนุญาตผูกกับเครื่อง	ย้ายเครื่องแล้วอีเมลหยุดส่งเงียบ ๆ	ตรวจ SMTP หลังย้าย/
ข้อมูลเดโมและตัวจำลองยังอยู่บนระบบ	ข้อมูลปลอมปนข้อมูลจริง ส่งอีเมลแจ้งเตือนจากข้อมูลปลอม	ล้างข้อมูลเดโมและหยุด
ยังไม่มี SMS, PDF จากเซิร์ฟเวอร์, SSO, แจ้งเตือนผู้ดูแลเมื่อมีการโจมตีหลายบัญชี	ฟีเจอร์เหล่านี้ใช้ไม่ได้	ดูแนวทางด้านล่าง
`/docs` (Swagger) เข้าได้โดยไม่ล็อกอิน	เปิดเผยโครงสร้าง API ต่อผู้ที่เข้าถึงเว็บได้	ปิดหรือจำกัดเมื่อเปิดสู่
สวิตช์ `style-src-attr 'unsafe-inline'` ใน CSP	ยอมให้ `style=""` ในแท็ก (UI ใช้มาก) เสี่ยงต่ำกว่าสคริปต์มาก	ค่อย ๆ ย้ายสไตล์เป็นค

11.2 แนวทางพัฒนาต่อ (เรียงตามความสำคัญ)

1. **ก่อนใช้งานจริงกับกองยานจริง:** ล้างข้อมูลเดโม หยุดตัวจำลอง ตั้งรหัสลับใหม่ถ้ายังใช้ค่าตอนพัฒนา เปิดนโยบายบังคับ 2FA ผู้ดูแล และทำสำเนากุญแจ age
2. **ความทนทาน:** เพิ่ม RAM/ดิสก์; เพิ่มสำเนาไฟล์สำรองไปยังที่เก็บภายนอก (S3-compatible) ควบคู่กับที่ดึงลงเครื่องผู้ดูแล; ทดสอบกู้เต็มระบบเป็นประจำ
3. **การเฝ้าระวัง:** ตรวจสถานะอัตโนมัติ (uptime, ใบรับรอง, ดิสก์, การส่งอีเมล) แจ้งผู้ดูแลเมื่อผิดปกติ
4. **ความปลอดภัย:** แจ้งผู้ดูแลเมื่อมีล็อกอินผิดข้ามหลายบัญชี; พิจารณา SSO; ถอด `unsafe-inline` ของสไตล์; จำกัดหรือปิด `/docs`
5. **ฟีเจอร์:** ส่งออก PDF จากเซิร์ฟเวอร์, SMS แจ้งเตือน, แจ้งผู้ขับ, การเลือกรับ LINE รายบุคคล, เก็บค่าก่อน/หลังแก้ของค่าตั้งสำคัญใน audit log
6. **การขยายระบบ:** ถ้าต้องขยายหลายอินสแตนซ์ ย้ายบัสเหตุการณ์และตัวนับจำกัดอัตราออกจากหน่วยความจำ

ภาคผนวก ก. รายการตารางในฐานข้อมูล (27 ตาราง)

ตาราง	หน้าที่
app_settings	ค่าตั้งองค์กร เกณฑ์แจ้งเตือน ช่องทาง ค่าไฟ (แถวเดียว) + นโยบายบังคับ 2FA + วันที่ส่งสรุปล่าสุด
users	บัญชีผู้ใช้ บทบาท สถานะ รหัสผ่าน (bcrypt) 2FA ตัวเลือกแจ้งเตือน
password_resets	โทเคนรีเซ็ตรหัสผ่าน (hash, ใช้ครั้งเดียว, หมดอายุ)
user_recovery_codes	รหัสสำรอง 2FA (hash, ใช้ครั้งเดียว)
api_keys	คีย์ของอุปกรณ์/ระบบภายนอก (hash, scope, เวลาใช้ล่าสุด, เพิกถอน)
audit_log	บันทึกกิจกรรม (แก้ไขไม่ได้)
integrations	สถานะการเชื่อมต่อระบบภายนอกที่แสดงในหน้าตั้งค่า
vehicle_models	รุ่นรถ
drivers	คนขับและคะแนน
vehicles	รถ สถานะล่าสุด แบตเตอรี่ ตำแหน่ง
vehicle_telemetry	ประวัติค่าตรวจวัดรายครั้งของรถ
trips	ทริปการเดินทาง
driving_events	เหตุการณ์การขับขี่
stations	สถานีชาร์จ (depot/public) ช่องชาร์จ ราคา
charging_sessions	เซสชันการชาร์จ (กำลังชาร์จ/จบ/หยุด)
charging_load	โหลดไฟรวมของ depot ตามช่วงเวลา
alerts	แจ้งเตือน (ระดับ ประเภท การรับทราบ การจองส่ง LINE/อีเมล)
alert_rules	กฎการแจ้งเตือนที่เปิด/ปิดได้
notification_channels	ช่องทางแจ้งเตือนและผู้รับ
maintenance_tasks	งานซ่อมบำรุงของรถ
energy_daily / energy_monthly	พลังงานและค่าใช้จ่ายรายวัน/เดือน
fleet_soh_monthly	สุขภาพแบตเตอรี่เฉลี่ยของกองยานรายเดือน
ice_vehicles	รถสันดาปที่ใช้เปรียบเทียบความพร้อมเปลี่ยนเป็น EV
tco_items	รายการต้นทุนรวม (TCO) ในรายงาน
report_config	สมมติฐานของรายงาน (ค่าคาร์บอน ค่าไฟ น้ำมัน ตัวเลขเปรียบเทียบ)
report_schedules	ตารางส่งรายงานทางอีเมล

ภาคผนวก ข. คำสั่งที่ใช้บ่อย

จัดการบัญชี (รันใน container api)

```
docker compose exec api node dist/cli.js create-admin --email <อีเมล> --name "<ชื่อ>"   # ถามรหัสแบบซ่อน
docker compose exec api node dist/cli.js set-password --email <อีเมล>
docker compose exec api node dist/cli.js reset-2fa    --email <อีเมล>
docker compose exec api node dist/cli.js list-users | check-defaults | retire-defaults
```

สำรอง/กู้คืน

```
docker compose exec -T backup sh /backup/backup.sh             # สำรองเดี๋ยวนี้
docker compose exec -T backup sh /backup/verify.sh             # ทดสอบกู้จริงลงฐานข้อมูลชั่วคราว
docker compose exec -T backup sh /backup/restore.sh <ไฟล์>     # กู้ลงฐานข้อมูลใหม่ (ปลอดภัย)
powershell -File db\backup\pull-offsite.ps1                    # ดึงไฟล์เข้ารหัสมาเครื่องผู้ดูแล
powershell -File db\backup\verify-offsite-local.ps1            # ถอดรหัสและนับตาราง
```

ทดสอบและรัน

```
docker compose --profile demo up --build -d     # เดโมในเครื่อง
cd api && npm test                               # ชุดทดสอบ API
docker compose ps ; docker compose logs api      # ตรวจสถานะ
```

> บน Windows ที่ใช้ Git Bash ให้ตั้ง `MSYS_NO_PATHCONV=1` นำหน้าเมื่อระบุพาธที่ขึ้นต้นด้วย `/` ในคำสั่ง `docker compose exec` มิฉะนั้นพาธจะถูกแปลงเป็นพาธของ Windows